

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM**



BÀI TẬP LỚN

TÊN HỌC PHẦN: AN TOÀN BẢO MẬT THÔNG TIN

**ĐỀ TÀI: NGHIÊN CỨU CHUYÊN SÂU VỀ CƠ CHẾ TẤN CÔNG, KỸ
THUẬT PHÁT HIỆN VÀ CHIẾN LƯỢC PHÒNG VỆ ĐỐI VỚI HIỂM HỌA
DENIAL-OF-SERVICE (DỰA TRÊN CHƯƠNG TRÌNH CHUẨN CEH
MODULE 09)**

STT	Mã Sinh Viên	Họ và Tên	Ngày Sinh	Lớp
1	1871020291	PHẠM QUANG HUY	06/11/2005	CNTT18-12
2	1871020597	Nguyễn Quang Trung	27/11/2006	CNTT18-12
3	1871020526	Lê Ngọc Thái	16/07/2006	CNTT18-12

Hà Nội, năm 2026



BÀI TẬP LỚN

TÊN HỌC PHẦN: BẢO MẬT THÔNG TIN

ĐỀ TÀI: NGHIÊN CỨU CHUYÊN SÂU VỀ CƠ CHẾ TẤN CÔNG, KỸ THUẬT PHÁT HIỆN VÀ CHIẾN LƯỢC PHÒNG VỆ ĐỐI VỚI HIỂM HỌA DENIAL-OF-SERVICE (DỰA TRÊN CHƯƠNG TRÌNH CHUẨN CEH MODULE 09)

STT	Mã Sinh Viên	Họ và Tên	Ngày Sinh	Điểm	
				Bảng Số	Bảng Chữ
1	1871020291	PHẠM QUANG HUY	06/11/2005		
2	1871020597	NGUYỄN QUANG TRUNG	27/11/2006		
3	1871020526	LÊ NGỌC THÁI	16/07/2006		

CÁN BỘ CHẤM THI 1

CÁN BỘ CHẤM THI 2

Hà Nội, Năm 2026

PHÂN CÔNG NHIỆM VỤ

STT	MSV	Họ và tên	Nhiệm vụ	Nhận xét của GV	Điểm đánh giá
1	1871020597	Nguyễn Quang Trung	Làm Code,Nghiên Cứu ,		
2	1871020526	Lê Ngọc Thái	Báo Cáo Slide,Phân tích		
3	1871020291	Phạm Quang Huy	Làm Code, Github,Chiến Lược		

LỜI NÓI ĐẦU

1. Tính cấp thiết của đề tài

Trong kỷ nguyên số hóa, hạ tầng mạng Internet đóng vai trò là mạch máu cốt lõi thúc đẩy toàn bộ nền kinh tế, xã hội toàn cầu. Sự phụ thuộc ngày càng lớn vào không gian mạng cũng mở ra những thách thức an ninh vô cùng khốc liệt. Giữa bối cảnh đó, tấn công Từ chối dịch vụ (Denial-of-Service - DoS) và Từ chối dịch vụ phân tán (Distributed Denial-of-Service - DDoS) nổi lên như một trong những hiểm họa công nghệ nguy hiểm, phổ biến và khó phòng chống nhất.

Sự tiến hóa của các cuộc tấn công DoS/DDoS không còn dừng lại ở các phương thức làm tràn ngập băng thông truyền thống mà đã chuyển dịch mạnh mẽ sang các kỹ thuật tinh vi như tấn công tầng ứng dụng (Layer 7 Flooding), tấn công phản xạ khuếch đại (DRDoS) tận dụng lỗ hổng cấu hình của các giao thức không hướng kết nối (UDP, NTP, Memcached), hay thậm chí là phá hoại vĩnh viễn phần cứng thiết bị (Phlashing). Với sự trợ giúp của các mạng lưới máy tính ma (Botnet) xuyên quốc gia và các công cụ tấn công mã nguồn mở được tối ưu hóa như HOIC, HULK, DoSHTTP, tội phạm mạng có thể dễ dàng vắt kiệt tài nguyên của những hệ thống máy chủ lớn chỉ trong vài giây.

Hậu quả của một cuộc tấn công DDoS không chỉ là sự gián đoạn dịch vụ tức thời, gây thiệt hại nặng nề về mặt tài chính do ngưng trệ giao dịch, mà còn làm xói mòn nghiêm trọng uy tín, danh tiếng của tổ chức và có khả năng đe dọa đến an ninh quốc gia. Do đó, việc nghiên cứu toàn diện về cơ chế hoạt động, kỹ thuật phát hiện, các kịch bản kiểm thử và chiến lược ứng phó đối với tấn công DoS/DDoS là một yêu cầu cấp thiết, đóng vai trò nền tảng để xây dựng hệ thống phòng thủ vững chắc cho mọi tổ chức trong tình hình mới.

2. Mục tiêu nghiên cứu

Nghiên cứu này được thực hiện nhằm đạt được các mục tiêu cốt lõi sau:

- **Hệ thống hóa lý thuyết nâng cao:** Phân tích chuyên sâu kiến trúc, nguyên lý vận hành và phân loại của các dạng tấn công DoS/DDoS dựa trên mô hình chuẩn hóa CEH.

- **Giải mã kỹ thuật cốt lõi:** Làm rõ cơ chế lan truyền mã độc của mạng lưới Botnet, các thuật toán tìm kiếm máy trạm dễ tổn thương và bản chất của hệ số khuếch đại (Amplification Factor) trong tấn công DRDoS.
- **Đánh giá giải pháp phát hiện và phòng vệ:** Phân tích các thuật toán định lượng (CUSUM, biến đổi Wavelet, Lập hồ sơ hoạt động) dùng để phát hiện bất thường luồng mạng, từ đó đề xuất ma trận chiến lược countermeasures (hấp thụ, hạ cấp hoặc cô lập dịch vụ) tối ưu.
- **Thực nghiệm kiểm thử xâm nhập:** Xây dựng quy trình giả lập tấn công có kiểm soát trong môi trường Lab, phân tích log giám sát dữ liệu thực tế bằng các công cụ chuyên dụng để tìm ra điểm gãy (Breaking Point) của hệ thống web, phục vụ công tác khắc phục lỗi hỏng chủ động.

3. Đối tượng và phạm vi nghiên cứu

- **Đối tượng nghiên cứu:** Các véc-tơ tấn công từ chối dịch vụ (Volumetric, Fragmentation, TCP State-Exhaustion, Application Layer Attacks), cấu trúc mạng lưới Botnet độc hại, công cụ tấn công chuyên dụng và các giải pháp/ thuật toán phòng thủ tương ứng.
- **Phạm vi nghiên cứu:** Đề tài tập trung nghiên cứu chuyên sâu dựa trên khung kiến thức bảo mật chuẩn CEH Module 09 (Denial-of-Service). Các nội dung thực nghiệm, phân tích gói tin mạng và cấu hình luật tường lửa được giới hạn thực hiện trong môi trường Lab giả lập an toàn, sử dụng hệ điều hành Kali Linux và Ubuntu Server, không gây ảnh hưởng đến hệ thống mạng thực tế.

Mục Lục

CHƯƠNG I: TỔNG QUAN VỀ TẤN CÔNG TỪ CHỐI DỊCH VỤ (DOS/DDOS CONCEPTS)	13
1. Định nghĩa kỹ thuật chuyên sâu	13
1.1. Bản chất học thuật của Tấn công từ chối dịch vụ (DoS - Denial of Service)	13
1.2. Cơ chế cốt lõi và sự cạn kiệt tài nguyên hệ thống	13
1.3. Hệ quả trực tiếp và các trạng thái lỗi hệ thống	14
2. Bản chất của Tấn công từ chối dịch vụ phân tán (DDoS)	14
2.1. Khái niệm và Kiến trúc Nguồn phát động Phân tán	14
2.2. Phương thức triển khai dựa trên kiến trúc mạng máy tính ma (Botnet)	15
2.3. Bón tác động nghiêm trọng của DoS/DDoS đối với tổ chức	15
CHƯƠNG II: BA CHIẾN LƯỢC VÀ PHƯƠNG PHÁP LAN TRUYỀN MÃ ĐỘC CỦA TỘI PHẠM MẠNG (MALICIOUS PROPAGATION TECHNIQUES)	18
2.1. Giới thiệu	18
2.2. Kỹ thuật Lan truyền từ Nguồn Tập trung (Central Source Propagation)	18
Khái niệm	18
Cơ chế hoạt động	19
Đặc điểm	19
Ưu điểm	19
Nhược điểm	20
Ví dụ minh họa	20
2.3. Kỹ thuật Lan truyền Chuỗi ngược (Back-chaining Propagation)	20
Khái niệm	20

Cơ chế hoạt động	20
Đặc điểm	21
Ưu điểm	21
Nhược điểm	21
Ví dụ minh họa	21
2.4. Kỹ thuật Lan truyền Tự trị (Autonomous Propagation)	21
Khái niệm	21
Cơ chế hoạt động	22
Đặc điểm	22
Ưu điểm	22
Nhược điểm	22
Ví dụ minh họa	23
2.5. So sánh ba phương pháp lan truyền mã độc	23
2.6. Kết luận chương	23
CHƯƠNG III: BỐN PHÂN LOẠI VÉC-TƠ TẤN CÔNG DOS/DDOS NÂNG CAO (ATTACK VECTORS)	24
3.1. Giới thiệu	24
3.2. Tấn công Thể tích / Băng thông (Volumetric Attacks)	25
3.2.1. Khái niệm	25
3.2.2. Cơ chế hoạt động	25
3.2.3. Các hình thức phổ biến	26
3.2.4. Đặc điểm	26
3.2.5. Ưu điểm đối với kẻ tấn công	26
3.2.6. Hạn chế	26

3.3. Tấn công Phân mảnh (Fragmentation Attacks)	26
3.3.1. Khái niệm	26
3.3.2. Cơ chế hoạt động	27
3.3.3. Một số kỹ thuật phổ biến	27
3.3.4. Đặc điểm	27
3.3.5. Ưu điểm	27
3.3.6. Hạn chế	27
3.4. Tấn công Kiệt quệ Trạng thái TCP (TCP State-Exhaustion Attacks)	28
3.4.1. Khái niệm	28
3.4.2. Cơ chế hoạt động	28
3.4.3. Các dạng phổ biến	28
3.4.4. Đặc điểm	28
3.4.5. Ưu điểm	28
3.4.6. Hạn chế	29
3.5. Tấn công Tầng Ứng dụng (Application Layer Attacks)	29
3.5.1. Khái niệm	29
3.5.2. Cơ chế hoạt động	29
3.5.3. Các kỹ thuật phổ biến	29
3.5.4. Đặc điểm	30
3.5.5. Ưu điểm	30
3.5.6. Hạn chế	30
3.6. So sánh bốn véc-tơ tấn công DoS/DDoS	30
3.7. Kết luận chương	31

CHƯƠNG IV: CƠ CHẾ SÂU CỦA CÁC KỸ THUẬT TẤN CÔNG THỰC TẾ (DETAILED ATTACK TECHNIQUES)	32
4.1. Giới thiệu	32
4.2. Tấn công lụt gói tin SYN (SYN Attacks & SYN Flooding)	32
4.2.1. Khái niệm	32
4.2.2. Nguyên lý bắt tay ba bước (Three-way Handshake)	32
4.2.3. Điểm yếu của giao thức TCP	33
4.2.4. Cơ chế tấn công	33
4.2.5. Hậu quả đối với hệ thống	33
4.2.6. Dấu hiệu nhận biết	34
4.2.7. Biện pháp phòng chống	34
4.3. Tấn công qua mạng ngang hàng (Peer-to-Peer Attacks)	34
4.3.1. Khái niệm	34
4.3.2. Cơ chế hoạt động	34
4.3.3. Hậu quả	35
4.3.4. Dấu hiệu nhận biết	35
4.3.5. Biện pháp phòng chống	35
4.4. Tấn công từ chối dịch vụ vĩnh viễn (Permanent Denial-of-Service – Phlashing)	35
4.4.1. Khái niệm	35
4.4.2. Cơ chế hoạt động	35
4.4.3. Đối tượng thường bị tấn công	36
4.4.4. Hậu quả	36
4.4.5. Dấu hiệu nhận biết	36
4.4.6. Biện pháp phòng chống	36

4.5. So sánh các kỹ thuật tấn công.....	36
4.6. Kết luận chương	37
CHƯƠNG V: KIẾN TRÚC VÀ HỆ SINH THÁI MẠNG LƯỚI MÁY TÍNH MA (BOTNET NETWORKS)	38
1. Quy trình thiết lập và điều khiển Botnet	38
2. Mô hình phân cấp cấu trúc tội phạm mạng có tổ chức (Organized Cyber Crime)	38
3. Năm phương pháp quét mạng tìm kiếm máy trạm dễ tổn thương (Scanning Methods)	39
CHƯƠNG VI: CÁC KỸ THUẬT PHÁT HIỆN TẤN CÔNG DOS/DDOS (DETECTION TECHNIQUES)	41
6.1. Giới thiệu	41
6.2. Kỹ thuật lập hồ sơ hoạt động (Activity Profiling)	41
6.2.1. Khái niệm	41
6.2.2. Nguyên lý hoạt động	42
6.2.3. Cơ chế phát hiện tấn công	42
6.2.4. Ưu điểm	43
6.2.5. Hạn chế	43
6.3. Kỹ thuật phân tích tín hiệu dựa trên Wavelet (Wavelet-based Signal Analysis)	43
6.3.1. Khái niệm	43
6.3.2. Nguyên lý hoạt động	43
6.3.3. Cơ chế phát hiện	44
6.3.4. Ưu điểm	44
6.3.5. Hạn chế	44
6.4. Thuật toán phát hiện điểm thay đổi tuần tự (Sequential Change-Point Detection)	44
6.4.1. Khái niệm	44

6.4.2. Quy trình hoạt động	44
6.4.3. Thuật toán CUSUM	45
6.4.4. Ưu điểm	45
6.4.5. Hạn chế	45
6.5. So sánh các kỹ thuật phát hiện	45
6.6. Kết luận chương	46
CHƯƠNG VII: CHIẾN LƯỢC VÀ CÔNG CỤ ỨNG PHÓ TRONG PHÒNG VỆ (COUNTERMEASURES)	47
7.1. Giới thiệu	47
7.2. Ba chiến lược ứng phó cốt lõi (Countermeasure Strategies)	47
7.2.1. Chiến lược hấp thụ cuộc tấn công (Absorbing the Attack)	47
7.2.2. Chiến lược hạ cấp dịch vụ (Degrading Services)	48
7.2.3. Chiến lược tắt hoàn toàn dịch vụ (Shutting Down the Services)	48
7.3. Các công cụ phòng chống DoS/DDoS chuyên dụng	49
7.3.1. Tường lửa thế hệ mới (Next-Generation Firewall – NGFW)	49
7.3.2. Thiết bị chống DDoS chuyên dụng (DDoS Mitigation Appliances)	49
7.3.3. Hệ thống phát hiện và ngăn chặn xâm nhập (Intrusion Detection System / Intrusion Prevention System)	50
7.3.4. Dịch vụ chống DDoS trên nền tảng đám mây (Cloud-based Scrubbing Services)	50
7.4. So sánh các công cụ phòng chống	51
7.5. Mô hình phòng thủ nhiều lớp	51
7.6. Kết luận chương	52
CHƯƠNG VIII: QUY TRÌNH KIỂM THỬ XÂM NHẬP DOS/DDOS (PENETRATION TESTING)	53

Bước 1: Giành quyền chấp thuận bằng văn bản (Written Permission & SLA)	53
Bước 2: Thu thập thông tin và xác định bề mặt tấn công (Reconnaissance)	54
Bước 3: Lập kịch bản và lựa chọn công cụ phù hợp	54
Bước 4: Thiết lập môi trường giám sát nền (Monitoring Baseline)	54
Bước 5: Thực hiện tấn công leo thang có kiểm soát (Execution)	55
Bước 6: Khôi phục hệ thống và lập báo cáo kiến nghị (Remediation & Reporting)	55
CHƯƠNG IX: PHÂN TÍCH CHUYÊN SÂU KIẾN TRÚC VÀ CƠ CHẾ KHUẾCH ĐẠI TRONG TẤN CÔNG PHẢN XẠ (DRDOS AMPLIFICATION METRICS)	56
1. Bản chất kỹ thuật của việc lựa chọn giao thức UDP	56
2. Bảng thống kê hệ số khuếch đại của các giao thức phổ biến	56
CHƯƠNG X: QUY TRÌNH GIÁM SÁT VÀ ĐIỀU TRA SỰ CỐ DDOS DÀNH CHO ĐỘI NGŨ AN NINH (SOC DRILL)	58
Bước 1: Trích xuất gói tin bằng công cụ lệnh TSHARK	58
Bước 2: Phân tích thống kê tìm địa chỉ IP nguồn tấn công	59
Bước 3: Cấu hình quy tắc tường lửa IPTABLES để chặn khẩn cấp	59
CHƯƠNG XI: MA TRẬN SO SÁNH GIỮA CÁC CÔNG CỤ TẤN CÔNG DOS/DDOS PHỔ BIẾN PHƯƠNG PHÁP LUẬN VÀ KẾT LUẬN BÁO CÁO	61
1. Phương pháp luận phòng thủ toàn diện	62
2. Kết luận	63
PHỤ LỤC A: TỪ ĐIỂN THUẬT NGỮ KỸ THUẬT CHUYÊN SÂU (GLOSSARY)	63
PHỤ LỤC B: DANH MỤC TÀI LIỆU THAM KHẢO	64

CHƯƠNG I: TỔNG QUAN VỀ TẤN CÔNG TỪ CHỐI DỊCH VỤ (DOS/DDOS CONCEPTS)

1. Định nghĩa kỹ thuật chuyên sâu

1.1. Bản chất học thuật của Tấn công từ chối dịch vụ (DoS - Denial of Service)

Trong mô hình bảo mật thông tin kinh điển CIA (Confidentiality - Tính bảo mật, Integrity - Tính toàn vẹn, Availability - Tính sẵn sàng), thuộc tính Sẵn sàng đóng vai trò đảm bảo rằng mọi tài nguyên số, dịch vụ mạng mạng và hạ tầng phần cứng phải luôn ở trạng thái hoạt động ổn định để đáp ứng nhu cầu truy cập của người dùng hợp pháp. Tấn công Từ chối Dịch vụ (DoS) là một hành vi phá hoại có chủ đích, nhằm trực tiếp vào việc triệt hạ thuộc tính Sẵn sàng này.

Về mặt kỹ thuật, DoS được định nghĩa là một cuộc tấn công mạng mạng, trong đó một tác nhân độc hại duy nhất tìm cách làm cho một thiết bị máy tính, một ứng dụng phần mềm hoặc toàn bộ hệ thống tài nguyên mạng mạng không thể sử dụng được bởi người dùng mục tiêu bằng cách làm gián đoạn tạm thời hoặc vĩnh viễn các dịch vụ kết nối (p. 5). Kẻ tấn công không cần phải bẻ khóa các cơ chế mật mã để đánh cắp dữ liệu, mà thay vào đó, chúng ép buộc hệ thống phải dừng hoạt động hoặc rơi vào trạng thái đóng băng cục bộ.

1.2. Cơ chế cốt lõi và sự cạn kiệt tài nguyên hệ thống

Cơ chế vận hành lõi của một cuộc tấn công DoS dựa trên nguyên lý bất đối xứng về mặt tài nguyên: kẻ tấn công sử dụng một lượng năng lực kích hoạt nhỏ để buộc hệ thống mục tiêu phải tiêu tốn một lượng tài nguyên xử lý cực lớn. Kẻ tấn công sẽ khởi tạo và gửi liên tiếp một lượng khổng lồ các yêu cầu dịch vụ bất hợp pháp, các gói tin dị dạng hoặc các dòng lưu lượng truy cập rác vào hệ thống mục tiêu một cách dồn dập (p. 5).

Quá trình oanh tạc này nhắm vào hai mục tiêu tài nguyên chiến lược của hạ tầng công nghệ thông tin:

- **Tài nguyên tính toán nội bộ (Compute Resources):** Bao gồm chu kỳ xử lý của bộ vi xử lý (CPU) và không gian lưu trữ động trên bộ nhớ truy cập ngẫu nhiên (RAM). Khi các gói tin độc hại dội vào máy chủ, nhân hệ điều hành (Kernel) bắt buộc phải tiêu thụ chu kỳ CPU để phân tích tiêu đề gói tin (Packet Header), tra cứu bảng trạng thái kết nối (Connection Tables) và phân bổ bộ nhớ RAM để tạo các cấu trúc quản lý tiến trình. Khi tốc độ gửi gói tin của hacker vượt quá năng lực tính toán của phần cứng, CPU sẽ bị đẩy lên mức sử dụng 100%, gây ra hiện tượng nghẽn cổ chai logic và máy chủ không còn tài nguyên để thực thi các tiến trình của hệ điều hành.
- **Tài nguyên băng thông đường truyền (Network Bandwidth):** Nhắm vào dung lượng truyền tải vật lý của công mạng dẫn vào trung tâm dữ liệu. Khi dòng lũ dữ liệu rác chiếm trọn dung lượng đường truyền Internet (ví dụ: cuộc tấn công đạt dung

lượng 10Gbps trong khi đường truyền của doanh nghiệp chỉ có giới hạn 1Gbps), toàn bộ "đường ống" dẫn dữ liệu sẽ bị lấp đầy bởi các gói tin bản.

1.3. Hệ quả trực tiếp và các trạng thái lỗi hệ thống

Hệ quả trực tiếp của các tác động trên là sự đứt gãy hoàn toàn trong chuỗi cung ứng dịch vụ số của tổ chức. Hệ thống sẽ rơi vào một trong hai trạng thái lỗi nghiêm trọng sau đây (p. 5):

- **Tình trạng cô lập hoàn toàn (Total Unavailability):** Máy chủ Web hoặc máy chủ ứng dụng bị sập nguồn, treo cứng hoặc tự động ngắt kết nối khỏi mạng mạng Internet do tràn bộ đệm hệ thống. Tại thời điểm này, trang web cụ thể hoàn toàn không thể truy cập được từ bên ngoài, mọi yêu cầu thiết lập kết nối mới từ phía người dùng hợp pháp đều nhận về các thông báo lỗi mã HTTP 503 (Service Unavailable) hoặc HTTP 504 (Gateway Timeout).
- **Tình trạng suy giảm hiệu năng nghiêm trọng (Performance Degradation):** Trong trường hợp hệ thống chưa sập hoàn toàn nhờ có các kiến trúc phần cứng mạnh, cuộc tấn công vẫn khiến cho hiệu năng hoạt động của toàn hệ thống mạng mạng bị chậm đi rõ rệt. Thời gian phản hồi (Latency) của các yêu cầu truy vấn dữ liệu bị kéo dài từ vài phần mười giây lên đến vài phút, tạo ra trải nghiệm tồi tệ và khiến các ứng dụng thời gian thực (như cổng thanh toán, API tài chính) bị ngắt kết nối tự động do hết hạn thời gian chờ (Timeout).

2. Bản chất của Tấn công từ chối dịch vụ phân tán (DDoS)

2.1. Khái niệm và Kiến trúc Nguồn phát động Phân tán

Khi các hệ thống tường lửa và các thiết bị chống DoS truyền thống ngày càng trở nên thông minh hơn, chúng dễ dàng phát hiện và chặn đứng (Drop) dòng lưu lượng độc hại nếu nó xuất phát từ một địa chỉ IP nguồn đơn lẻ của một máy tính duy nhất. Để vượt qua hàng rào phòng thủ này, tội phạm mạng đã phát triển một hình thức tấn công phức tạp và có sức công phá hủy diệt hơn rất nhiều: Tấn công Từ chối Dịch vụ Phân tán (DDoS - Distributed Denial of Service).

Về mặt kiến trúc mạng mạng, điểm khác biệt mang tính bản chất của DDoS so với DoS là sự dịch chuyển từ cấu trúc tấn công đơn điểm (One-to-One) sang cấu trúc tấn công đa điểm hội tụ (Many-to-One). Một cuộc tấn công DDoS sẽ huy động một số lượng khổng lồ các hệ thống máy tính, máy chủ, điện thoại di động, hoặc các thiết bị Internet vạn vật (IoT) đã bị thỏa hiệp (bị nhiễm độc mã độc ngầm và bị hacker chiếm quyền điều khiển tối cao) trên toàn cầu để cùng đồng loạt hướng dòng thác lưu lượng tấn công vào một mục tiêu đơn lẻ duy nhất (p. 6).

Lúc này, mục tiêu không phải đối đầu với một kẻ thù đơn độc, mà phải gồng mình chống đỡ một trận bão lưu lượng dội về từ hàng vạn hướng địa lý khác nhau trên bản đồ mạng mạng Internet toàn cầu.

2.2. Phương thức triển khai dựa trên kiến trúc mạng máy tính ma (Botnet)

Để phát động một chiến dịch DDoS trên diện rộng, kẻ tấn công (thường gọi là Botmaster) bắt buộc phải xây dựng và sử dụng các mạng lưới máy tính ma, được thuật ngữ chuyên ngành gọi là **Botnet** (p. 6). Quy trình triển khai một cấu trúc Botnet diễn ra theo một chiến dịch tinh vi gồm nhiều giai đoạn: lây nhiễm mã độc tự động thông qua các lỗ hổng phần mềm, chiếm quyền kiểm soát root/administrator của thiết bị nạn nhân, cài đặt các đoạn mã cửa sau (Backdoors) duy trì sự ẩn mình, và kết nối các thiết bị bị nhiễm (được gọi là các Bots hoặc Zombies) về một hệ thống máy chủ điều khiển trung tâm C&C (Command and Control).

Khi Botmaster muốn đánh sập một mục tiêu, chúng chỉ cần phát ra một lệnh tấn công duy nhất từ máy chủ C&C. Ngay lập tức, lệnh này được nhân bản và truyền bá xuyên suốt mạng lưới Botnet. Hàng vạn máy ma Zombie sẽ đồng loạt giải phóng các vector tấn công (như SYN Flood, UDP Flood, HTTP GET Flood) hướng về địa chỉ IP của nạn nhân. Dòng lưu lượng rác xuất phát từ hàng ngàn nguồn IP hoàn toàn khác nhau dồn về cùng một thời điểm sẽ tạo ra một áp lực nén vật lý cực đại.

Các thiết bị phòng thủ biên như Tường lửa trạng thái (Stateful Firewall) khi đối mặt với DDoS sẽ bị bão hòa năng lực tra cứu bảng trạng thái (State Table) do số lượng địa chỉ IP nguồn quá lớn và thay đổi liên tục, từ đó làm bẻ gãy mọi bộ lọc an ninh thông thường của doanh nghiệp.

2.3. Bốn tác động nghiêm trọng của DoS/DDoS đối với tổ chức

Sự phá hoại của tấn công DoS/DDoS không chỉ để lại những tổn thất kỹ thuật tạm thời mà gây ra những hệ lụy mang tính chuỗi dây chuyền, phá hủy toàn diện các giá trị cốt lõi của một thực thể tổ chức. Dựa trên các nghiên cứu an ninh mạng, bốn tác động nghiêm trọng nhất bao gồm (p. 6):

HỆ LỤY TOÀN DIỆN CỦA TẤN CÔNG DoS/DDoS

1. Loss of Goodwill (Tổn hại nghiêm trọng danh tiếng tổ chức)
2. Disabled Network (Vô hiệu hóa toàn bộ hạ tầng mạng mạng biên)
3. Financial Loss (Thiệt hại nặng nề về doanh thu trực tiếp)
4. Disabled Organization (Tê liệt hoàn toàn bộ máy vận hành)

A. Loss of Goodwill (Tổn hại danh tiếng)

Đối với bất kỳ một tổ chức nào trong nền kinh tế số, lòng tin và danh tiếng thương hiệu (Goodwill) là tài sản vô hình vô giá nhưng lại dễ bị tổn thương nhất. Khi một cuộc tấn công DDoS làm đóng băng các dịch vụ trực tuyến của doanh nghiệp (như ứng dụng Mobile Banking của ngân hàng, trang web giao dịch e-Commerce), khách hàng và đối tác chiến lược sẽ không thể thực hiện các thao tác công việc cần thiết.

Sự gián đoạn này nếu kéo dài sẽ kích hoạt tâm lý hoang mang, hoài nghi của cộng đồng về năng lực bảo mật và tính ổn định của tổ chức. Danh tiếng bị xói mòn nghiêm trọng trên các phương tiện truyền thông, dẫn đến làn sóng tẩy chay dịch vụ và khách hàng sẽ dịch chuyển sang sử dụng sản phẩm của đối thủ cạnh tranh (p. 6).

B. Disabled Network (Vô hiệu hóa hệ thống mạng mạng)

Tác động kỹ thuật trực tiếp nhất của DDoS là làm tê liệt hạ tầng mạng mạng của toàn doanh nghiệp (p. 6). Khi các Router biên, bộ chuyển mạch Core Switch và các thiết bị cân bằng tải bị bão hòa năng lực xử lý gói tin, toàn bộ cấu trúc mạng mạng nội bộ (LAN) và mạng mạng diện rộng (WAN) của tổ chức sẽ bị cô lập hoàn toàn.

Hệ thống không thể định tuyến cho các luồng dữ liệu hợp pháp đi vào hoặc đi ra. Điều này đồng nghĩa với việc các kênh truyền thông như hệ thống Email doanh nghiệp, tổng đài IP Phone, các kết nối VPN của nhân viên làm việc từ xa đều bị cắt đứt, biến doanh nghiệp thành một "hòn đảo hoang" cô độc trên không gian mạng mạng.

C. Financial Loss (Thiệt hại nặng nề về mặt tài chính)

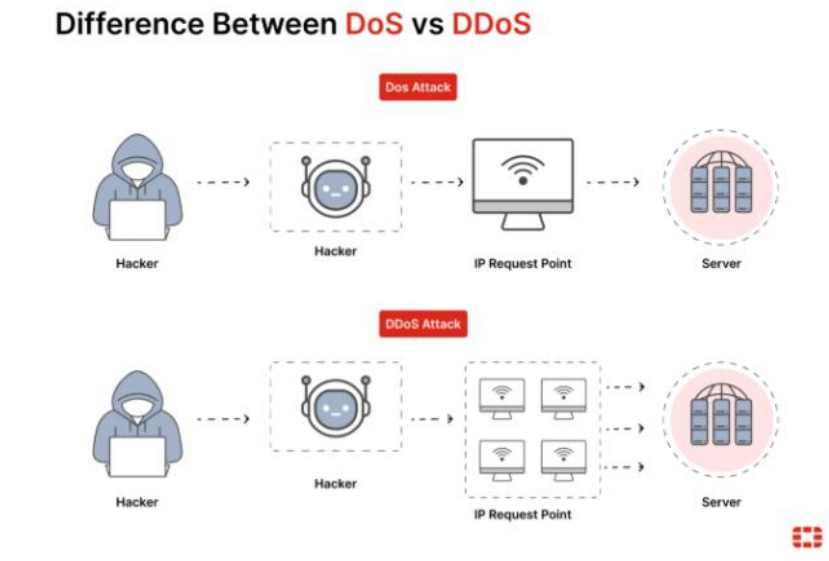
DDoS là một đòn giáng nặng nề trực tiếp vào bài toán kinh tế của doanh nghiệp. Thiệt hại tài chính được cấu thành từ ba nguồn chi phí khổng lồ:

- *Thất thoát doanh thu trực tiếp:* Đối với các nền tảng bán hàng hoặc sàn giao dịch trực tuyến, mỗi phút sập hệ thống (Downtime) tỷ lệ thuận với hàng ngàn giao dịch bị hủy bỏ, gây mất mát dòng tiền ngay tức thì không thể thu hồi.
- *Chi phí ứng cứu và khắc phục sự cố:* Tổ chức phải chi trả các khoản ngân sách khẩn cấp cực kỳ đắt đỏ để thuê các chuyên gia phản ứng nhanh, mua thêm băng thông ứng cứu từ nhà mạng (ISP) và chi phí làm việc tăng ca của đội ngũ nhân sự CNTT.
- *Hình phạt vi phạm hợp đồng SLA:* Doanh nghiệp cung cấp dịch vụ công nghệ thường ký kết cam kết mức độ dịch vụ (Service Level Agreement - SLA) với khách hàng. Khi DDoS làm ngưng trệ dịch vụ vượt quá thời gian cho phép, tổ chức sẽ phải đối mặt với các nghĩa vụ đền bù tài chính và phạt pháp lý rất nặng (p. 6).

D. Disabled Organization (Tê liệt toàn bộ tổ chức)

Hệ quả cuối cùng và nguy hiểm nhất của một cuộc tấn công DDoS quy mô lớn là đẩy toàn bộ tổ chức vào trạng thái tê liệt hoàn toàn (p. 6). Trong mô hình vận hành hiện đại, mọi phòng ban từ Nhân sự, Kế toán, Kinh doanh cho đến Chuỗi cung ứng đều làm việc dựa trên các phần mềm nền tảng đám mây (SaaS) và hệ thống quản trị nguồn lực doanh nghiệp (ERP).

Khi hạ tầng mạng mạng bị vô hiệu hóa, toàn bộ cán bộ công nhân viên sẽ hoàn toàn không thể truy cập được vào cơ sở dữ liệu, không thể kiểm tra kho hàng, không thể phê duyệt chứng từ và không thể chăm sóc khách hàng. Toàn bộ bộ máy vận hành hành chính và sản xuất của doanh nghiệp bị đóng băng hoàn toàn, gây ra tình trạng trì trệ toàn diện trong cấu trúc tổ chức.



Hình ảnh minh họa

CHƯƠNG II: BA CHIẾN LƯỢC VÀ PHƯƠNG PHÁP LAN TRUYỀN MÃ ĐỘC CỦA TỘI PHẠM MẠNG (MALICIOUS PROPAGATION TECHNIQUES)

Để xây dựng được mạng lưới Botnet phục vụ cho mục đích DDoS, kẻ tấn công áp dụng các kỹ thuật tinh vi sau nhằm phát tán mã độc (Malicious Code) vào các hệ thống mục tiêu mới phát hiện (p. 25).

2.1. Giới thiệu

Trong các cuộc tấn công từ chối dịch vụ phân tán (Distributed Denial-of-Service - DDoS), việc xây dựng một mạng Botnet có quy mô lớn là bước quan trọng quyết định mức độ thành công của cuộc tấn công. Để hình thành Botnet, kẻ tấn công phải phát tán mã độc đến càng nhiều hệ thống càng tốt, từ đó biến các máy tính hoặc thiết bị IoT bị xâm nhập thành các "bot" có khả năng nhận lệnh từ máy chủ điều khiển và tham gia thực hiện các cuộc tấn công quy mô lớn.

Quá trình phát tán mã độc không chỉ dựa trên việc khai thác các lỗ hổng bảo mật của hệ điều hành hoặc ứng dụng, mà còn sử dụng nhiều chiến lược khác nhau nhằm tối ưu tốc độ lây lan, giảm khả năng bị phát hiện và tăng khả năng duy trì mạng Botnet trong thời gian dài.

Theo chương trình đào tạo CEH Module 09, có ba chiến lược lan truyền mã độc phổ biến gồm:

- Lan truyền từ nguồn tập trung (Central Source Propagation)
- Lan truyền chuỗi ngược (Back-chaining Propagation)
- Lan truyền tự trị (Autonomous Propagation)

Mỗi chiến lược đều có cơ chế hoạt động, ưu điểm, nhược điểm và phạm vi áp dụng khác nhau.

2.2. Kỹ thuật Lan truyền từ Nguồn Tập trung (Central Source Propagation)

Khái niệm

Lan truyền từ nguồn tập trung là phương pháp mà toàn bộ mã độc và công cụ khai thác được lưu trữ trên một máy chủ trung tâm do kẻ tấn công quản lý. Máy chủ này đóng vai trò như kho lưu trữ duy nhất chứa các thành phần cần thiết để lây nhiễm sang những hệ thống mới.

Sau khi khai thác thành công một máy nạn nhân, máy bị nhiễm sẽ tự động kết nối về máy chủ trung tâm để tải toàn bộ mã độc, cài đặt vào hệ thống và tiếp tục tham gia quá trình phát tán.

Phương pháp này từng được sử dụng phổ biến trong giai đoạn đầu của các cuộc tấn công Botnet do cấu trúc đơn giản, dễ triển khai và dễ quản lý.

Cơ chế hoạt động

Quy trình hoạt động của kỹ thuật này diễn ra theo các bước sau:

Bước 1: Kẻ tấn công tiến hành quét Internet hoặc mạng nội bộ để tìm kiếm các thiết bị tồn tại lỗ hổng bảo mật.

Bước 2: Sau khi phát hiện mục tiêu phù hợp, kẻ tấn công thực hiện khai thác lỗ hổng nhằm chiếm quyền thực thi lệnh trên máy nạn nhân.

Bước 3: Một đoạn mã nhỏ (Downloader) được thực thi trên hệ thống bị xâm nhập.

Bước 4: Downloader sẽ thiết lập kết nối đến máy chủ trung tâm thông qua HTTP, HTTPS, FTP hoặc các giao thức truyền tệp khác.

Bước 5: Máy nạn nhân tải toàn bộ bộ công cụ mã độc từ máy chủ trung tâm và tiến hành cài đặt.

Bước 6: Sau khi hoàn tất cài đặt, máy bị nhiễm sẽ tiếp tục quét mạng để tìm kiếm những nạn nhân mới và lặp lại toàn bộ quy trình.

Đặc điểm

Một số đặc điểm nổi bật của phương pháp này bao gồm:

- Có một máy chủ trung tâm lưu trữ toàn bộ mã độc.
- Dễ dàng cập nhật phiên bản mã độc mới.
- Kẻ tấn công có thể quản lý toàn bộ hệ thống từ một vị trí duy nhất.
- Dễ triển khai đối với các Botnet quy mô nhỏ và trung bình.

Ưu điểm

- Quản lý tập trung giúp việc cập nhật mã độc trở nên nhanh chóng.
- Có thể thay đổi hoặc bổ sung chức năng của Botnet mà không cần lây nhiễm lại từ đầu.
- Tiết kiệm dung lượng gói khai thác vì chỉ cần tải mã độc sau khi khai thác thành công.

Nhược điểm

Tuy mang lại nhiều thuận lợi trong quản lý, phương pháp này tồn tại một điểm yếu nghiêm trọng.

Máy chủ trung tâm trở thành **điểm lỗi duy nhất (Single Point of Failure)**. Nếu máy chủ bị phát hiện, bị chặn hoặc bị cơ quan chức năng thu giữ, toàn bộ quá trình phát tán mã độc sẽ bị gián đoạn.

Ngoài ra, lưu lượng truy cập từ nhiều máy nạn nhân cùng kết nối về một địa chỉ IP cũng dễ bị các hệ thống IDS/IPS hoặc Firewall phát hiện.

Ví dụ minh họa

Một số Botnet đời đầu sử dụng mô hình tập trung thông qua máy chủ IRC hoặc HTTP để điều khiển toàn bộ các máy bị nhiễm. Sau khi chiếm quyền điều khiển, các bot sẽ kết nối đến máy chủ Command and Control (C&C) nhằm nhận lệnh thực hiện tấn công DDoS hoặc tải thêm các thành phần độc hại khác.

2.3. Kỹ thuật Lan truyền Chuỗi ngược (Back-chaining Propagation)

Khái niệm

Khác với mô hình tập trung, phương pháp Back-chaining không sử dụng một máy chủ riêng để lưu trữ mã độc. Thay vào đó, toàn bộ bộ công cụ tấn công được đặt trực tiếp trên máy tính của kẻ tấn công.

Sau khi khai thác thành công một hệ thống, máy nạn nhân sẽ chủ động tạo kết nối ngược trở lại máy của hacker nhằm tải xuống mã độc.

Cơ chế hoạt động

Quá trình lan truyền diễn ra như sau:

Bước 1: Hacker quét mạng để tìm kiếm mục tiêu có lỗ hổng.

Bước 2: Tiến hành khai thác và giành quyền thực thi mã trên máy nạn nhân.

Bước 3: Máy nạn nhân tự động thiết lập kết nối ngược về máy tính của hacker.

Bước 4: Mã độc được sao chép từ máy hacker sang máy nạn nhân.

Bước 5: Máy bị nhiễm tiếp tục quét mạng để tìm kiếm nạn nhân mới.

Quá trình này diễn ra liên tục cho đến khi số lượng bot đạt yêu cầu.

Đặc điểm

- Không cần máy chủ trung gian.
- Mọi dữ liệu đều được lưu trên máy của hacker.
- Quá trình sao chép diễn ra thông qua kết nối ngược.
- Dễ triển khai trong các cuộc tấn công quy mô nhỏ.

Ưu điểm

- Tiết kiệm chi phí triển khai.
- Không cần thuê máy chủ điều khiển.
- Hacker có toàn quyền kiểm soát mã độc.

Nhược điểm

Máy tính của hacker trở thành điểm kết nối duy nhất.

Nếu địa chỉ IP bị phát hiện hoặc máy tính bị tắt, toàn bộ quá trình phát tán sẽ bị dừng.

Ngoài ra, số lượng kết nối lớn quay về cùng một máy tính cũng dễ gây nghi ngờ cho các hệ thống giám sát mạng.

Ví dụ minh họa

Một số biến thể Trojan trong giai đoạn đầu sử dụng kỹ thuật Reverse Connection để kết nối trực tiếp về máy của hacker trước khi tải các thành phần độc hại.

2.4. Kỹ thuật Lan truyền Tự trị (Autonomous Propagation)

Khái niệm

Lan truyền tự trị là phương pháp hiện đại và nguy hiểm nhất. Khác với hai phương pháp trước, mã khai thác và mã độc được tích hợp trong cùng một gói tin.

Ngay khi khai thác thành công lỗ hổng, mã độc sẽ tự động thực thi mà không cần tải thêm bất kỳ tệp nào từ bên ngoài.

Điều này giúp quá trình lây lan diễn ra với tốc độ rất cao.

Cơ chế hoạt động

Quy trình hoạt động bao gồm:

Bước 1: Hacker tạo một gói tin chứa đồng thời mã khai thác và mã độc.

Bước 2: Gửi gói tin đến hệ thống mục tiêu.

Bước 3: Nếu lỗ hổng tồn tại, mã khai thác sẽ giành quyền điều khiển hệ thống.

Bước 4: Mã độc ngay lập tức được kích hoạt.

Bước 5: Máy bị nhiễm tự động quét Internet hoặc mạng LAN để tìm kiếm nạn nhân mới.

Bước 6: Quá trình tiếp tục lặp lại mà không cần bất kỳ sự can thiệp nào từ hacker.

Đặc điểm

- Không cần máy chủ trung gian.
- Không cần tải thêm mã độc.
- Có khả năng tự sao chép.
- Tốc độ phát tán rất cao.
- Khó ngăn chặn sau khi bắt đầu lây lan.

Ưu điểm

- Tốc độ lây nhiễm cực nhanh.
- Không phụ thuộc vào máy chủ điều khiển.
- Có khả năng lây lan trên diện rộng chỉ trong thời gian ngắn.
- Khó bị ngắt quãng nếu một nút trong mạng bị loại bỏ.

Nhược điểm

Do tốc độ phát tán quá nhanh nên loại hình này thường tạo ra lưu lượng mạng bất thường, khiến các hệ thống giám sát dễ phát hiện.

Ngoài ra, nếu mã độc tồn tại lỗi lập trình, nó có thể tự làm gián đoạn quá trình lây lan hoặc gây ra các hành vi ngoài ý muốn.

Ví dụ minh họa

Các sâu máy tính (Worm) như **Code Red**, **Slammer** và **WannaCry** đều sử dụng cơ chế lan truyền gần với mô hình tự trị. Sau khi khai thác thành công lỗ hổng, chúng tự động quét mạng và tiếp tục lây nhiễm mà không cần người điều khiển can thiệp trực tiếp.

2.5. So sánh ba phương pháp lan truyền mã độc

Tiêu chí	Central Source	Back-chaining	Autonomous
Máy chủ trung tâm	Có	Không	Không
Nguồn lấy mã độc	Máy chủ	Máy hacker	Có sẵn trong gói khai thác
Tốc độ lây lan	Trung bình	Nhanh	Rất nhanh
Khả năng quản lý	Cao	Trung bình	Thấp
Khả năng bị phát hiện	Trung bình	Cao	Thấp hơn trong giai đoạn đầu
Mức độ nguy hiểm	Trung bình	Cao	Rất cao

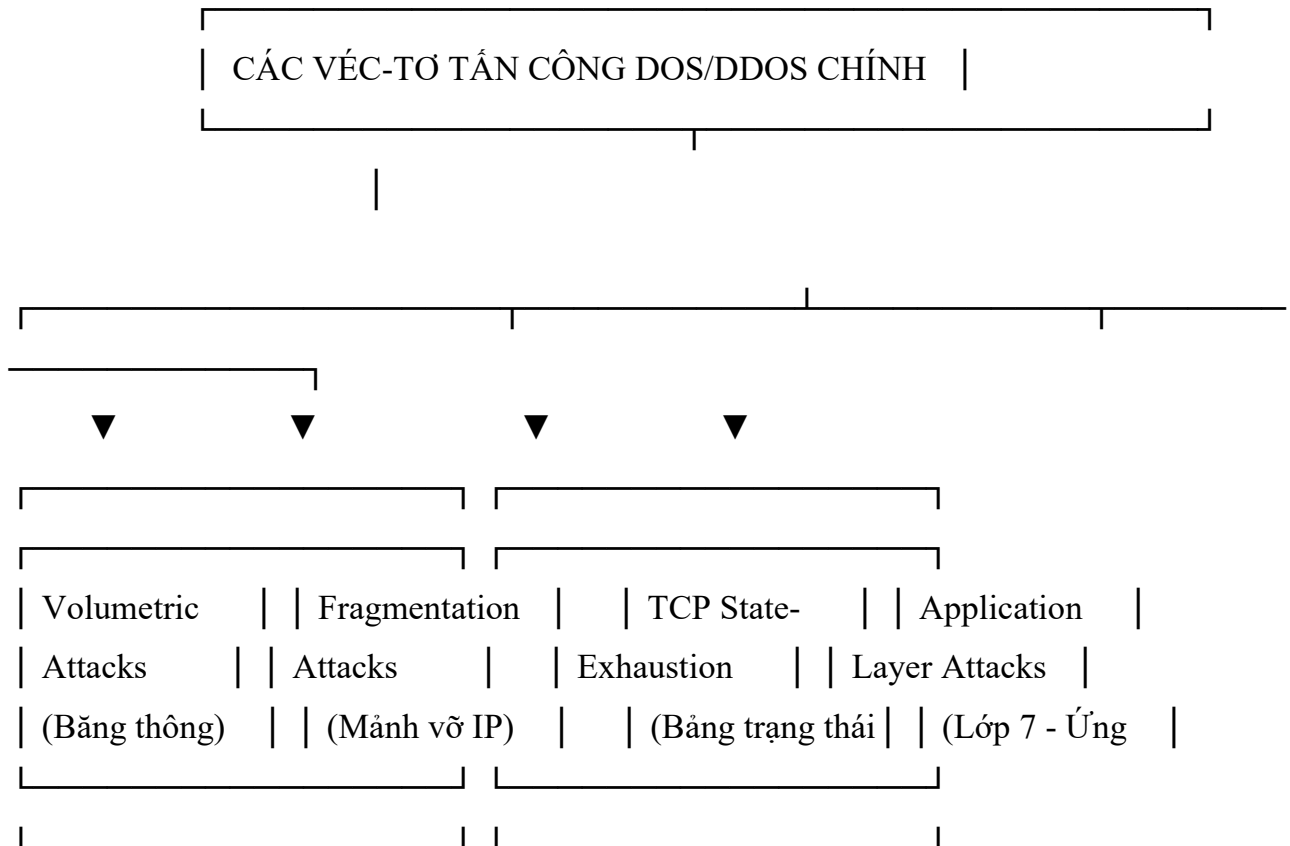
2.6. Kết luận chương

Ba chiến lược lan truyền mã độc đều hướng đến mục tiêu mở rộng nhanh số lượng thiết bị bị kiểm soát để hình thành mạng Botnet phục vụ các cuộc tấn công DDoS. Trong đó, **Central Source Propagation** có ưu điểm về khả năng quản lý nhưng phụ thuộc vào máy chủ trung tâm; **Back-chaining Propagation** loại bỏ máy chủ trung gian nhưng vẫn phụ thuộc vào máy của kẻ tấn công; còn **Autonomous Propagation** có tốc độ phát tán nhanh nhất nhờ khả năng tự thực thi và tự lây lan mà không cần tải thêm mã độc.

Việc hiểu rõ cơ chế hoạt động, ưu điểm và hạn chế của từng phương pháp giúp các nhà quản trị hệ thống lựa chọn các giải pháp giám sát, phát hiện và phòng chống phù hợp nhằm hạn chế nguy cơ hình thành Botnet và giảm thiểu tác động của các cuộc tấn công DDoS

CHƯƠNG III: BỐN PHÂN LOẠI VÉC-TƠ TẤN CÔNG DOS/DDOS NÂNG CAO (ATTACK VECTORS)

Theo chuẩn hóa kiến thức bảo mật CEH, toàn bộ các hình thức tấn công từ chối dịch vụ được chia thành 4 nhóm véc-tơ cốt lõi nhằm vào các tầng cấu trúc hạ tầng khác nhau (p. 9):



3.1. Giới thiệu

Tấn công từ chối dịch vụ (Denial-of-Service - DoS) và tấn công từ chối dịch vụ phân tán (Distributed Denial-of-Service - DDoS) là những mối đe dọa nghiêm trọng đối với hạ tầng công nghệ thông tin hiện nay. Mục tiêu của các cuộc tấn công này là làm suy giảm hoặc vô hiệu hóa khả năng cung cấp dịch vụ của hệ thống thông qua việc tiêu thụ tài nguyên mạng, tài nguyên tính toán hoặc khai thác các điểm yếu trong giao thức và ứng dụng.

Theo chương trình đào tạo **Certified Ethical Hacker (CEH) Module 09**, các hình thức tấn công DoS/DDoS được phân thành bốn nhóm véc-tơ chính dựa trên đối tượng mà chúng tác động. Mỗi nhóm sử dụng những kỹ thuật khác nhau nhằm làm cạn kiệt tài nguyên của hệ thống mục tiêu, từ băng thông mạng, bộ nhớ lưu trạng thái kết nối cho đến tài nguyên xử lý của các ứng dụng web.

Bốn nhóm véc-tơ tấn công bao gồm:

- **Volumetric Attacks (Tấn công thể tích hoặc băng thông)**
- **Fragmentation Attacks (Tấn công phân mảnh gói tin)**
- **TCP State-Exhaustion Attacks (Tấn công làm cạn kiệt bảng trạng thái TCP)**
- **Application Layer Attacks (Tấn công tầng ứng dụng)**

Việc phân loại này giúp các chuyên gia bảo mật dễ dàng xác định bản chất của cuộc tấn công và lựa chọn các giải pháp phòng thủ phù hợp với từng loại.

3.2. Tấn công Thể tích / Băng thông (Volumetric Attacks)

3.2.1. Khái niệm

Volumetric Attack là hình thức tấn công DDoS phổ biến nhất, trong đó kẻ tấn công tạo ra một lượng lưu lượng mạng (Traffic) cực lớn nhằm làm bão hòa băng thông truyền dẫn giữa người dùng và hệ thống mục tiêu. Khi băng thông bị sử dụng hết, các yêu cầu hợp lệ từ người dùng sẽ không thể truyền đến máy chủ, dẫn đến tình trạng dịch vụ bị gián đoạn hoặc ngừng hoạt động hoàn toàn.

Đặc điểm nổi bật của nhóm tấn công này là không nhất thiết phải khai thác lỗ hổng phần mềm mà chủ yếu lợi dụng giới hạn về khả năng truyền tải dữ liệu của hạ tầng mạng.

3.2.2. Cơ chế hoạt động

Quy trình thực hiện thường diễn ra như sau:

Bước 1: Kẻ tấn công điều khiển mạng Botnet gồm hàng nghìn hoặc hàng triệu thiết bị bị nhiễm mã độc.

Bước 2: Toàn bộ Bot đồng thời gửi các gói tin đến cùng một địa chỉ IP hoặc một dịch vụ cụ thể.

Bước 3: Các gói tin được gửi liên tục với tốc độ rất cao, tạo ra lưu lượng vượt quá khả năng xử lý của đường truyền.

Bước 4: Router, Switch hoặc Firewall bắt đầu bị quá tải.

Bước 5: Băng thông Internet bị chiếm dụng hoàn toàn.

Bước 6: Người dùng hợp pháp không thể truy cập vào dịch vụ.

3.2.3. Các hình thức phổ biến

Một số kỹ thuật thuộc nhóm Volumetric Attack gồm:

- UDP Flood
- ICMP Flood (Ping Flood)
- DNS Amplification
- NTP Amplification
- SSDP Amplification
- Memcached Amplification

Trong đó, các cuộc tấn công khuếch đại (Amplification Attack) đặc biệt nguy hiểm vì chỉ cần gửi một lượng nhỏ dữ liệu nhưng có thể tạo ra lượng phản hồi lớn gấp hàng chục hoặc hàng trăm lần.

3.2.4. Đặc điểm

- Tiêu thụ băng thông mạng.
- Dễ triển khai bằng Botnet.
- Không cần khai thác lỗ hổng ứng dụng.
- Có thể tạo lưu lượng lên tới hàng trăm Gbps hoặc thậm chí Tbps.

3.2.5. Ưu điểm đối với kẻ tấn công

- Thực hiện đơn giản.
- Hiệu quả cao đối với các hệ thống có đường truyền hạn chế.
- Khó phân biệt giữa lưu lượng hợp lệ và lưu lượng độc hại khi quy mô rất lớn.

3.2.6. Hạn chế

- Cần số lượng Bot rất lớn.
- Dễ bị giảm thiểu bởi CDN, Anycast hoặc các trung tâm lọc lưu lượng DDoS.

3.3. Tấn công Phân mảnh (Fragmentation Attacks)

3.3.1. Khái niệm

Fragmentation Attack là nhóm tấn công khai thác cơ chế phân mảnh của giao thức IP. Trong điều kiện bình thường, khi một gói tin lớn hơn giá trị MTU của mạng truyền dẫn, nó sẽ được chia thành nhiều mảnh nhỏ để truyền đi và được lắp ráp lại tại thiết bị đích.

Kẻ tấn công lợi dụng chính cơ chế này bằng cách gửi các gói tin phân mảnh bất thường nhằm làm tiêu tốn tài nguyên xử lý của máy chủ hoặc thiết bị mạng.

3.3.2. Cơ chế hoạt động

Quá trình tấn công diễn ra như sau:

Bước 1: Tạo các gói IP bị phân mảnh.

Bước 2: Làm sai lệch thứ tự hoặc nội dung các mảnh.

Bước 3: Gửi hàng nghìn hoặc hàng triệu mảnh đến máy chủ.

Bước 4: Máy chủ liên tục lưu các mảnh trong bộ nhớ để chờ lắp ráp.

Bước 5: Do thiếu mảnh hoặc mảnh bị lỗi, việc lắp ráp không thể hoàn thành.

Bước 6: Bộ nhớ và CPU bị tiêu tốn dẫn đến suy giảm hiệu năng hoặc treo hệ thống.

3.3.3. Một số kỹ thuật phổ biến

- Teardrop Attack
- Ping of Death
- Fragment Flood
- Tiny Fragment Attack

3.3.4. Đặc điểm

- Tấn công trực tiếp vào tầng mạng.
- Khai thác điểm yếu trong quá trình tái lắp ráp gói tin.
- Tiêu tốn RAM và CPU của thiết bị.

3.3.5. Ưu điểm

- Không cần lượng băng thông quá lớn.
- Có thể làm treo các hệ điều hành hoặc thiết bị cũ.

3.3.6. Hạn chế

- Hầu hết hệ điều hành hiện đại đã vá các lỗi phân mảnh cổ điển.
- Firewall hiện đại có khả năng loại bỏ các gói phân mảnh bất thường.

3.4. Tấn công Kiệt quệ Trạng thái TCP (TCP State-Exhaustion Attacks)

3.4.1. Khái niệm

Khác với Volumetric Attack, TCP State-Exhaustion không tập trung vào việc làm nghẽn băng thông mà nhằm tiêu hao bộ nhớ dùng để quản lý các kết nối TCP.

Các thiết bị như Firewall, Load Balancer và Web Server đều duy trì bảng trạng thái (State Table) để theo dõi các phiên TCP đang hoạt động. Khi bảng này đầy, hệ thống không thể tiếp nhận các kết nối mới.

3.4.2. Cơ chế hoạt động

Quy trình tấn công gồm:

Bước 1: Gửi liên tục các gói SYN đến máy chủ.

Bước 2: Máy chủ phản hồi SYN-ACK.

Bước 3: Hacker không gửi ACK cuối cùng.

Bước 4: Máy chủ tiếp tục giữ trạng thái kết nối trong bộ nhớ.

Bước 5: Hàng triệu kết nối giả được tạo ra.

Bước 6: Bảng trạng thái đầy và từ chối người dùng thật.

3.4.3. Các dạng phổ biến

- SYN Flood
- ACK Flood
- TCP Connection Flood
- Connection Exhaustion Attack

3.4.4. Đặc điểm

- Không yêu cầu lưu lượng quá lớn.
- Chủ yếu tiêu hao RAM và Connection Table.
- Rất hiệu quả với Firewall và Load Balancer.

3.4.5. Ưu điểm

- Dễ vượt qua nhiều cơ chế giới hạn băng thông.

- Có thể đánh sập máy chủ bằng lượng dữ liệu tương đối nhỏ.

3.4.6. Hạn chế

- Các hệ điều hành hiện đại thường hỗ trợ SYN Cookies hoặc cơ chế bảo vệ bảng trạng thái.
- IDS/IPS có thể phát hiện lưu lượng SYN bất thường.

3.5. Tấn công Tầng Ứng dụng (Application Layer Attacks)

3.5.1. Khái niệm

Application Layer Attack là nhóm tấn công nhắm trực tiếp vào tầng ứng dụng (Layer 7) trong mô hình OSI. Đây là loại tấn công phức tạp nhất vì lưu lượng gửi đến thường giống với các yêu cầu hợp lệ của người dùng.

Mục tiêu của nhóm tấn công này là làm cạn kiệt tài nguyên xử lý của ứng dụng như CPU, bộ nhớ, kết nối cơ sở dữ liệu hoặc luồng xử lý.

3.5.2. Cơ chế hoạt động

Quy trình gồm:

Bước 1: Hacker nghiên cứu cấu trúc website hoặc API.

Bước 2: Xác định các chức năng tiêu tốn tài nguyên.

Bước 3: Gửi số lượng lớn yêu cầu HTTP hợp lệ.

Bước 4: Máy chủ phải xử lý từng yêu cầu.

Bước 5: CPU, RAM và Database bị quá tải.

Bước 6: Website phản hồi chậm hoặc ngừng hoạt động.

3.5.3. Các kỹ thuật phổ biến

- HTTP GET Flood
- HTTP POST Flood
- Slowloris
- Slow POST
- RUDY Attack
- HTTP/2 Rapid Reset Attack

- DNS Query Flood

3.5.4. Đặc điểm

- Lưu lượng nhỏ nhưng hiệu quả cao.
- Khó phân biệt với người dùng thật.
- Chủ yếu tiêu hao tài nguyên ứng dụng.

3.5.5. Ưu điểm

- Không cần Botnet quá lớn.
- Dễ vượt qua Firewall truyền thống.
- Hiệu quả đối với các website thương mại điện tử, ngân hàng, hệ thống API và dịch vụ trực tuyến.

3.5.6. Hạn chế

- Cần nghiên cứu kỹ ứng dụng trước khi tấn công.
- Dễ bị giảm thiểu bởi Web Application Firewall (WAF), cơ chế giới hạn tốc độ (Rate Limiting) và CDN.

3.6. So sánh bốn véc-tơ tấn công DoS/DDoS

Tiêu chí	Volumetric	Fragmentation	TCP State-Exhaustion	Application Layer
Mục tiêu	Băng thông	Cơ chế phân mảnh IP	Bảng trạng thái TCP	Tài nguyên ứng dụng
Tầng OSI	Layer 3/4	Layer 3	Layer 4	Layer 7
Tài nguyên bị tiêu hao	Băng thông	CPU, RAM	Bộ nhớ trạng thái kết nối	CPU, RAM, Database
Mức độ tinh vi	Thấp	Trung bình	Cao	Rất cao
Khả năng phát hiện	Dễ	Trung bình	Khó	Khó nhất

Tiêu chí	Volumetric	Fragmentation	TCP State-Exhaustion	Application Layer
Ví dụ	UDP Flood, DNS Amplification	Teardrop, Ping of Death	SYN Flood	HTTP Flood, Slowloris

3.7. Kết luận chương

Bốn nhóm véc-tơ tấn công DoS/DDoS được phân loại theo CEH Module 09 phản ánh các hướng tiếp cận khác nhau mà kẻ tấn công sử dụng để làm gián đoạn dịch vụ. **Volumetric Attacks** tập trung làm nghẽn băng thông mạng bằng lượng lưu lượng cực lớn; **Fragmentation Attacks** khai thác cơ chế phân mảnh và tái lắp ráp gói tin IP để tiêu tốn tài nguyên xử lý; **TCP State-Exhaustion Attacks** hướng đến việc làm cạn kiệt bảng trạng thái kết nối TCP của máy chủ và thiết bị mạng; trong khi **Application Layer Attacks** nhắm trực tiếp vào tầng ứng dụng, khai thác các chức năng tiêu tốn tài nguyên nhằm làm suy giảm hoặc vô hiệu hóa dịch vụ.

Việc hiểu rõ đặc điểm, cơ chế hoạt động và tác động của từng nhóm véc-tơ tấn công là cơ sở quan trọng để xây dựng các giải pháp phát hiện, giám sát và phòng chống hiệu quả. Trong các chương tiếp theo, báo cáo sẽ tiếp tục phân tích các kỹ thuật nhận diện và các chiến lược phòng vệ phù hợp đối với từng loại hình tấn công DoS/DDoS

CHƯƠNG IV: CƠ CHẾ SÂU CỦA CÁC KỸ THUẬT TẤN CÔNG THỰC TẾ (DETAILED ATTACK TECHNIQUES)

4.1. Giới thiệu

Trong thực tế, các cuộc tấn công từ chối dịch vụ (DoS) và từ chối dịch vụ phân tán (DDoS) không chỉ dừng lại ở việc tạo ra lượng lưu lượng truy cập lớn nhằm làm nghẽn đường truyền mạng, mà còn khai thác các điểm yếu trong giao thức truyền thông, kiến trúc mạng và phần mềm ứng dụng để làm cạn kiệt tài nguyên của hệ thống. Mỗi kỹ thuật tấn công đều có cơ chế hoạt động, đối tượng tác động và mức độ nguy hiểm khác nhau. Một số kỹ thuật chỉ gây gián đoạn dịch vụ trong thời gian ngắn, trong khi một số khác có thể khiến thiết bị hư hỏng hoàn toàn và không thể khôi phục.

Theo nội dung của chương trình CEH Module 09, ba kỹ thuật được nghiên cứu trong chương này bao gồm tấn công SYN Flood, tấn công thông qua mạng ngang hàng (Peer-to-Peer Attack) và tấn công từ chối dịch vụ vĩnh viễn (Permanent Denial-of-Service – Phlashing). Đây là những kỹ thuật tiêu biểu phản ánh nhiều phương thức khai thác khác nhau của tội phạm mạng đối với hệ thống máy chủ và hạ tầng mạng hiện đại.

4.2. Tấn công lụt gói tin SYN (SYN Attacks & SYN Flooding)

4.2.1. Khái niệm

SYN Flood là một trong những kỹ thuật tấn công DoS/DDoS lâu đời nhưng vẫn rất hiệu quả cho đến ngày nay. Hình thức tấn công này khai thác trực tiếp quy trình thiết lập kết nối của giao thức TCP nhằm làm cạn kiệt bộ nhớ và bảng quản lý kết nối của máy chủ.

Khác với các cuộc tấn công bằng thông, SYN Flood không cần tạo ra lưu lượng dữ liệu quá lớn mà tập trung vào việc duy trì số lượng rất lớn các kết nối chưa hoàn tất. Điều này khiến máy chủ phải dành tài nguyên để theo dõi các kết nối giả mạo, dẫn đến việc từ chối phục vụ các kết nối hợp lệ từ người dùng.

4.2.2. Nguyên lý bắt tay ba bước (Three-way Handshake)

Giao thức TCP sử dụng cơ chế bắt tay ba bước để đảm bảo việc thiết lập kết nối diễn ra an toàn và tin cậy.

Ở bước đầu tiên, máy khách (Host A) gửi một gói tin SYN đến máy chủ nhằm yêu cầu thiết lập kết nối.

Sau khi nhận được gói SYN, máy chủ (Host B) sẽ phản hồi bằng một gói SYN-ACK và đồng thời tạo một bản ghi trong hàng đợi kết nối (Listen Queue hoặc SYN Queue). Tại thời điểm này, kết nối mới chỉ ở trạng thái mở một phần (Half-open Connection).

Cuối cùng, máy khách gửi gói ACK để xác nhận việc thiết lập kết nối. Khi ACK được nhận, kết nối TCP được hình thành hoàn chỉnh và hai bên có thể bắt đầu trao đổi dữ liệu.

Chính khoảng thời gian chờ gói ACK cuối cùng đã tạo ra điểm yếu để kẻ tấn công khai thác.

4.2.3. Điểm yếu của giao thức TCP

Để đảm bảo các gói tin có thể đến nơi ngay cả khi mạng có độ trễ, hầu hết các hệ điều hành đều duy trì trạng thái của các kết nối mở trong một khoảng thời gian nhất định trước khi tự động hủy bỏ. Trong nhiều trường hợp, thời gian này có thể kéo dài khoảng 75 giây.

Trong suốt khoảng thời gian chờ đợi đó, máy chủ vẫn phải sử dụng bộ nhớ để lưu thông tin về địa chỉ IP, cổng kết nối, số thứ tự gói tin và nhiều thông tin quản lý khác. Nếu có quá nhiều kết nối ở trạng thái chờ, tài nguyên hệ thống sẽ nhanh chóng bị tiêu hao.

4.2.4. Cơ chế tấn công

Trong cuộc tấn công SYN Flood, kẻ tấn công gửi liên tục số lượng rất lớn các gói SYN đến máy chủ. Điểm đặc biệt là các gói tin này thường sử dụng địa chỉ IP nguồn giả mạo (IP Spoofing).

Máy chủ tin rằng đây là những yêu cầu hợp lệ nên phản hồi bằng gói SYN-ACK và tạo bản ghi trong hàng đợi kết nối để chờ gói ACK cuối cùng.

Do địa chỉ IP nguồn không tồn tại hoặc đã bị giả mạo, máy chủ sẽ không bao giờ nhận được gói ACK xác nhận. Những kết nối này tiếp tục tồn tại trong trạng thái Half-open cho đến khi hết thời gian chờ.

Nếu hàng chục nghìn hoặc hàng trăm nghìn yêu cầu SYN được gửi trong thời gian ngắn, toàn bộ hàng đợi kết nối sẽ bị lấp đầy. Khi đó, máy chủ không còn khả năng tiếp nhận các yêu cầu kết nối hợp lệ từ người dùng thật.

4.2.5. Hậu quả đối với hệ thống

Cuộc tấn công SYN Flood có thể gây ra nhiều ảnh hưởng nghiêm trọng.

Hàng đợi kết nối TCP bị chiếm đầy bởi các kết nối giả mạo.

Bộ nhớ của máy chủ bị tiêu hao để lưu trữ trạng thái của các kết nối chưa hoàn tất.

CPU phải xử lý số lượng lớn yêu cầu thiết lập kết nối.

Người dùng hợp pháp không thể truy cập website hoặc dịch vụ.

Thời gian phản hồi của hệ thống tăng cao, thậm chí toàn bộ dịch vụ có thể ngừng hoạt động.

4.2.6. Dấu hiệu nhận biết

Khi xảy ra SYN Flood, quản trị viên thường quan sát thấy số lượng kết nối ở trạng thái SYN_RECV tăng đột biến. Nhật ký của Firewall và IDS/IPS ghi nhận số lượng lớn các gói SYN từ nhiều địa chỉ IP khác nhau. Trong khi đó, người dùng phản ánh việc truy cập dịch vụ trở nên chậm hoặc thường xuyên gặp lỗi timeout mặc dù đường truyền Internet vẫn hoạt động bình thường.

4.2.7. Biện pháp phòng chống

Để giảm thiểu nguy cơ bị tấn công SYN Flood, các tổ chức thường kích hoạt cơ chế SYN Cookies nhằm hạn chế việc lưu trạng thái kết nối trước khi hoàn tất quá trình bắt tay TCP. Bên cạnh đó, việc cấu hình giới hạn tốc độ kết nối, sử dụng Firewall thế hệ mới, hệ thống IDS/IPS và các dịch vụ chống DDoS trên nền tảng đám mây sẽ giúp phát hiện cũng như loại bỏ các yêu cầu bất thường trước khi chúng đến máy chủ.

4.3. Tấn công qua mạng ngang hàng (Peer-to-Peer Attacks)

4.3.1. Khái niệm

Peer-to-Peer Attack là kỹ thuật tấn công lợi dụng các mạng chia sẻ ngang hàng (P2P) để tạo ra lưu lượng truy cập rất lớn đến hệ thống mục tiêu. Thay vì sử dụng Botnet truyền thống, kẻ tấn công khai thác các điểm yếu của giao thức hoặc phần mềm P2P để khiến các máy tính của người dùng vô tình trở thành nguồn phát sinh lưu lượng.

Các mạng P2P như Direct Connect (DC++), BitTorrent hoặc một số hệ thống chia sẻ dữ liệu khác cho phép các máy tính kết nối trực tiếp với nhau mà không cần máy chủ trung tâm. Chính đặc điểm này đã tạo điều kiện cho tội phạm mạng lợi dụng để điều hướng lưu lượng.

4.3.2. Cơ chế hoạt động

Kẻ tấn công khai thác lỗ hổng trong giao thức hoặc gửi các thông điệp điều khiển giả mạo khiến nhiều máy khách đang tham gia mạng P2P đồng loạt ngắt kết nối khỏi máy chủ hiện tại.

Sau đó, các máy tính này được điều hướng đến một địa chỉ IP hoặc một trang web do kẻ tấn công chỉ định. Do tất cả các máy đều thực hiện kết nối gần như đồng thời, hệ thống mục tiêu phải tiếp nhận một lượng lớn yêu cầu trong thời gian rất ngắn.

Điểm nguy hiểm là toàn bộ lưu lượng đều xuất phát từ các máy tính hợp pháp của người dùng nên rất khó phân biệt với truy cập thông thường.

4.3.3. Hậu quả

Lượng lớn kết nối đồng thời làm tiêu hao băng thông Internet, CPU, bộ nhớ và tài nguyên của máy chủ. Website hoặc dịch vụ trực tuyến phản hồi chậm, không thể phục vụ người dùng hoặc bị gián đoạn hoàn toàn. Đồng thời, việc truy vết nguồn gốc cuộc tấn công trở nên khó khăn vì lưu lượng đến từ nhiều quốc gia và nhiều địa chỉ IP khác nhau.

4.3.4. Dấu hiệu nhận biết

Hệ thống xuất hiện số lượng lớn yêu cầu truy cập từ nhiều địa chỉ IP phân tán trên phạm vi rộng. Mặc dù các yêu cầu có vẻ hợp lệ, nhưng tần suất và mô hình truy cập lại giống nhau bất thường. Nhật ký máy chủ ghi nhận lượng kết nối tăng đột biến trong thời gian ngắn.

4.3.5. Biện pháp phòng chống

Các tổ chức nên thường xuyên cập nhật phần mềm P2P để vá các lỗ hổng bảo mật, triển khai cơ chế xác thực nguồn truy cập, áp dụng giới hạn tốc độ kết nối và sử dụng CDN hoặc hệ thống chống DDoS để phân tán lưu lượng. Việc giám sát lưu lượng theo thời gian thực cũng giúp phát hiện sớm các dấu hiệu bất thường.

4.4. Tấn công từ chối dịch vụ vĩnh viễn (Permanent Denial-of-Service – Phlashing)

4.4.1. Khái niệm

Permanent Denial-of-Service (PDoS), hay còn gọi là Phlashing, là một trong những hình thức tấn công nguy hiểm nhất vì mục tiêu không chỉ là làm gián đoạn dịch vụ mà còn gây hư hỏng lâu dài đối với thiết bị phần cứng.

Không giống các cuộc tấn công DoS truyền thống chỉ ảnh hưởng trong thời gian ngắn, PDoS tác động trực tiếp đến firmware hoặc phần mềm điều khiển thiết bị. Khi firmware bị ghi đè hoặc bị hỏng, thiết bị có thể mất hoàn toàn khả năng khởi động.

4.4.2. Cơ chế hoạt động

Kẻ tấn công thường kết hợp các kỹ thuật lừa đảo xã hội như email giả mạo, tin nhắn, đường liên kết độc hại hoặc các bản cập nhật phần mềm giả để chiếm quyền điều khiển thiết bị.

Sau khi có quyền quản trị, đối tượng tấn công tiến hành thay đổi hoặc ghi đè firmware bằng dữ liệu không hợp lệ. Trong một số trường hợp, firmware bị thay thế bằng mã độc hoặc dữ liệu rác khiến thiết bị không còn khả năng hoạt động bình thường.

Do firmware được lưu trong bộ nhớ ROM hoặc Flash Memory, việc ghi sai dữ liệu có thể khiến thiết bị không thể khởi động lại nếu không có công cụ phục hồi chuyên dụng.

4.4.3. Đối tượng thường bị tấn công

Permanent DoS thường nhắm đến các thiết bị mạng và thiết bị nhúng như Router, Switch, Firewall, Camera IP, thiết bị IoT, máy chủ, hệ thống lưu trữ NAS và các bộ điều khiển công nghiệp. Đây đều là những thiết bị có vai trò quan trọng trong hạ tầng công nghệ thông tin.

4.4.4. Hậu quả

Firmware bị hỏng khiến thiết bị không thể khởi động.

Toàn bộ dịch vụ do thiết bị cung cấp bị gián đoạn.

Tổ chức phải tốn nhiều chi phí để sửa chữa hoặc thay thế phần cứng.

Nguy cơ mất dữ liệu và gián đoạn hoạt động kinh doanh tăng cao.

Thời gian khôi phục hệ thống kéo dài hơn rất nhiều so với các cuộc tấn công DoS thông thường.

4.4.5. Dấu hiệu nhận biết

Sau khi bị tấn công, thiết bị không thể khởi động hoặc liên tục khởi động lại. Giao diện quản trị không còn truy cập được và firmware không thể cập nhật theo cách thông thường. Một số thiết bị chỉ hiển thị đèn báo lỗi hoặc hoàn toàn không có tín hiệu hoạt động.

4.4.6. Biện pháp phòng chống

Để hạn chế nguy cơ xảy ra Permanent DoS, các tổ chức cần sử dụng firmware được cung cấp từ nhà sản xuất chính thức và kiểm tra chữ ký số trước khi cập nhật. Tài khoản quản trị phải được bảo vệ bằng xác thực đa yếu tố, đồng thời cần hạn chế quyền truy cập từ Internet. Việc sao lưu cấu hình định kỳ và theo dõi các hoạt động cập nhật firmware sẽ giúp giảm thiểu thiệt hại nếu xảy ra sự cố.

4.5. So sánh các kỹ thuật tấn công

Tiêu chí	SYN Flood	Peer-to-Peer Attack	Permanent DoS (Phlashing)
Mục tiêu tấn công	Bảng trạng thái TCP	Bảng thông và kết nối	Firmware và phần cứng
Đối tượng bị ảnh	Máy chủ, Firewall, Load	Máy chủ và hạ tầng	Router, Switch, IoT,

Tiêu chí	SYN Flood	Peer-to-Peer Attack	Permanent DoS (Phlashing)
hường	Balancer	mạng	máy chủ
Tài nguyên bị tiêu hao	Bộ nhớ và băng kết nối	Băng thông, CPU	Firmware và thiết bị
Mức độ ảnh hưởng	Tạm thời	Tạm thời	Có thể vĩnh viễn
Khả năng khôi phục	Dễ	Dễ	Khó hoặc phải thay thiết bị

4.6. Kết luận chương

Ba kỹ thuật tấn công được trình bày trong chương này đại diện cho những phương pháp phổ biến mà tội phạm mạng sử dụng để gây gián đoạn hoặc phá hủy hệ thống. SYN Flood khai thác điểm yếu trong quá trình thiết lập kết nối TCP để làm cạn kiệt bảng trạng thái của máy chủ. Peer-to-Peer Attack lợi dụng các mạng chia sẻ ngang hàng nhằm tạo ra lượng lớn lưu lượng truy cập từ nhiều nguồn hợp pháp. Trong khi đó, Permanent Denial-of-Service (Phlashing) hướng đến việc phá hủy firmware và phần cứng, gây ra hậu quả nghiêm trọng và kéo dài.

Việc hiểu rõ cơ chế hoạt động, dấu hiệu nhận biết và tác động của từng kỹ thuật không chỉ giúp nâng cao khả năng phát hiện sớm các cuộc tấn công mà còn là cơ sở để xây dựng các chiến lược phòng thủ hiệu quả. Đây cũng là nền tảng quan trọng cho chương tiếp theo, trong đó sẽ trình bày các kỹ thuật phát hiện và các giải pháp bảo vệ hệ thống trước các mối đe dọa DoS/DDoS.

CHƯƠNG V: KIẾN TRÚC VÀ HỆ SINH THÁI MẠNG LƯỚI MÁY TÍNH MA (BOTNET NETWORKS)

1. Quy trình thiết lập và điều khiển Botnet

Mạng lưới Botnet hoạt động như một hệ thống phân cấp quân đội số, được vận hành chặt chẽ qua 6 bước cốt lõi (p. 21):

1. **Thiết lập hạ tầng:** Kẻ tấn công thiết lập máy chủ điều khiển Bot Command and Control Center (C&C Center) và cài đặt một trình xử lý điều khiển (C&C Handler) (p. 21).
2. **Xâm nhập ban đầu:** Kẻ tấn công tiến hành dò quét và thực hiện hành vi lây nhiễm mã độc thành công lên một máy nạn nhân đầu tiên (Victim/Bot) (p. 21).
3. **Tự động nhân bản:** Mã độc trên máy Bot này tự động quét môi trường mạng xung quanh, tìm kiếm các hệ thống có lỗ hổng tương tự để lây nhiễm, tự động mở rộng quy mô mạng lưới Botnet (p. 21).
4. **Kết nối đăng ký:** Tất cả các máy tính bị chiếm quyền (Zombies) tự động thực hiện kết nối ngược về máy chủ C&C Handler để báo cáo trạng thái trực tuyến và chờ đợi lệnh (p. 21).
5. **Phát lệnh tập trung:** Khi cần tấn công, kẻ tấn công chỉ cần gửi duy nhất một dòng lệnh xuống máy chủ C&C (p. 21). Hệ thống C&C sẽ tự động phân phối lệnh đồng loạt đến hàng vạn máy Zombie cùng lúc (p. 21).
6. **Đồng loạt xả lũ:** Toàn bộ mạng lưới máy ma nhận lệnh, đồng loạt hướng luồng dữ liệu tấn công (như ICMP Echo Flood) về phía máy chủ mục tiêu (Target Server), làm tê liệt dịch vụ ngay lập tức (p. 21).

2. Mô hình phân cấp cấu trúc tội phạm mạng có tổ chức (Organized Cyber Crime)

Trong thế giới ngầm, việc vận hành Botnet được chuyên môn hóa cao theo mô hình doanh nghiệp kim tự tháp (p. 20):

- **Criminal Boss (Trùm tội phạm):** Đứng ở đỉnh kim tự tháp, điều hành toàn bộ chiến dịch, đưa ra mục tiêu chiến lược và phân phối lợi nhuận tài chính (p. 20).

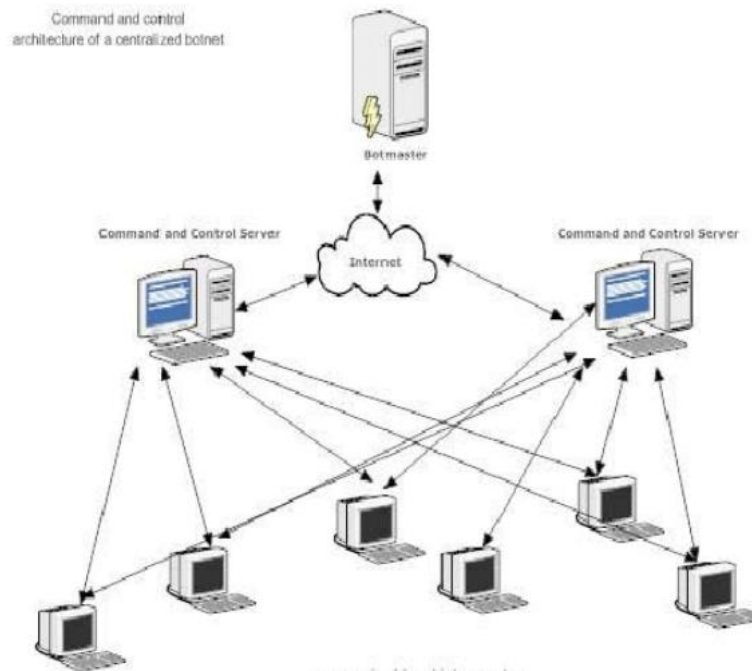
- **Underboss (Trùm phó / Nhà cung cấp Trojan):** Trực tiếp quản lý và vận hành kỹ thuật hệ thống lệnh Trojan Command and Control; phân phối các bộ công cụ tạo mã độc (Crimeware Toolkit Owners) xuống cấp dưới (p. 20).
- **Campaign Manager (Quản lý chiến dịch):** Điều phối các hoạt động phát tán mã độc cụ thể, chịu trách nhiệm nhúng Trojan vào các website hợp pháp để bẫy người dùng (p. 20).
- **Affiliation Network (Mạng lưới đại lý liên kết):** Các nhóm tin tặc cấp thấp thực hiện nhiệm vụ phát tán, lây nhiễm mã độc trên diện rộng để xây dựng và cho thuê quyền lực Botnet (p. 20).
- **Stolen Data Reseller (Bên trung gian bán dữ liệu đánh cắp):** Thu thập thông tin thẻ tín dụng, tài khoản ngân hàng từ hệ sinh thái Botnet để bán lại ra thị trường đen (p. 20).

3. Năm phương pháp quét mạng tìm kiếm máy trạm dễ tổn thương (Scanning Methods)

Để tuyển dụng thêm các máy Zombie mới, mã độc Botnet áp dụng 5 thuật toán dò quét tự động sau (p. 24):

- **Random Scanning (Quét ngẫu nhiên):** Máy bị nhiễm tự động phát các gói tin kiểm tra lỗ hổng tới các địa chỉ IP được chọn hoàn toàn ngẫu nhiên trong toàn bộ không gian mạng Internet (p. 24).
- **Hit-list Scanning (Quét theo danh sách có sẵn):** Kẻ tấn công thu thập từ trước một danh sách các máy chủ có tiềm năng chứa lỗ hổng lớn, sau đó ra lệnh cho Botnet quét tập trung vào danh sách này để đẩy nhanh tiến độ chiếm quyền (p. 24).
- **Topological Scanning (Quét theo cấu trúc liên kết):** Mã độc tận dụng chính các thông tin nội bộ thu thập được trên máy đã bị nhiễm (như lịch sử duyệt web, danh bạ email, bảng định tuyến) để tìm ra và tấn công các mục tiêu có liên quan (p. 24).
- **Local Subnet Scanning (Quét mạng con nội bộ):** Bot chủ động dò tìm và quét các máy tính nằm chung trong dải dải mạng nội bộ (LAN/Subnet) của nó để lây lan theo chiều ngang với tốc độ cực nhanh do không bị chặn bởi tường lửa biên (p. 24).

- **Permutation Scanning (Quét hoán vị):** Sử dụng một thuật toán danh sách hoán vị giả ngẫu nhiên (pseudorandom permutation list) để phân chia dải IP cho các Bot khác nhau, đảm bảo không có hai Bot nào quét trùng một địa chỉ IP, tối ưu hóa hiệu suất lây nhiễm (p. 24).



Hình ảnh minh họa

CHƯƠNG VI: CÁC KỸ THUẬT PHÁT HIỆN TẤN CÔNG DOS/DDOS (DETECTION TECHNIQUES)

Mục tiêu cốt lõi của các kỹ thuật phát hiện là xác định và phân biệt chính xác giữa sự gia tăng lưu lượng truy cập bất hợp pháp và các sự kiện tăng trưởng lưu lượng hợp pháp (Flash Crowd) (p. 40). Tất cả các thuật toán phát hiện đều định nghĩa một cuộc tấn công là một sự lệch hướng bất thường và có thể nhận biết được so với ngưỡng thống kê lưu lượng mạng thông thường (p. 40).

6.1. Giới thiệu

Trong bối cảnh các cuộc tấn công DoS và DDoS ngày càng gia tăng cả về quy mô lẫn mức độ tinh vi, việc phát hiện sớm đóng vai trò đặc biệt quan trọng trong chiến lược bảo vệ hệ thống. Nếu các cuộc tấn công được nhận diện ngay từ giai đoạn đầu, quản trị viên có thể nhanh chóng triển khai các biện pháp ứng phó như lọc lưu lượng, giới hạn tốc độ truy cập hoặc chuyển hướng lưu lượng đến các trung tâm chống DDoS nhằm giảm thiểu thiệt hại.

Mục tiêu của các kỹ thuật phát hiện không chỉ là xác định sự tồn tại của lưu lượng bất thường mà còn phải phân biệt chính xác giữa một cuộc tấn công DDoS và các trường hợp tăng lưu lượng hợp lệ (Flash Crowd), chẳng hạn như khi một chương trình khuyến mại lớn được triển khai, một sự kiện thể thao diễn ra hoặc một tin tức quan trọng khiến lượng người truy cập tăng đột biến. Nếu hệ thống nhận diện sai, các biện pháp phòng vệ có thể vô tình chặn cả người dùng hợp pháp, gây ảnh hưởng đến chất lượng dịch vụ.

Theo chương trình CEH Module 09, phần lớn các thuật toán phát hiện đều dựa trên nguyên lý xây dựng mô hình lưu lượng bình thường của hệ thống, sau đó liên tục so sánh với lưu lượng thực tế để phát hiện các sai lệch vượt quá ngưỡng thống kê cho phép. Khi xuất hiện các biến động bất thường về tốc độ truyền dữ liệu, số lượng kết nối hoặc mô hình truy cập, hệ thống sẽ kích hoạt cảnh báo và hỗ trợ các giải pháp phòng thủ.

Ba kỹ thuật phát hiện được sử dụng phổ biến gồm kỹ thuật lập hồ sơ hoạt động (Activity Profiling), kỹ thuật phân tích tín hiệu bằng Wavelet (Wavelet-based Signal Analysis) và thuật toán phát hiện điểm thay đổi tuần tự (Sequential Change-Point Detection).

6.2. Kỹ thuật lập hồ sơ hoạt động (Activity Profiling)

6.2.1. Khái niệm

Activity Profiling là một trong những kỹ thuật phát hiện DDoS phổ biến nhất hiện nay. Phương pháp này xây dựng một hồ sơ hoạt động chuẩn của hệ thống dựa trên việc quan sát hành vi lưu lượng mạng trong điều kiện hoạt động bình thường. Hồ sơ này được xem như

"mô hình tham chiếu", giúp hệ thống xác định các sai lệch khi xuất hiện lưu lượng bất thường.

Khác với các phương pháp chỉ theo dõi tổng số lượng gói tin, Activity Profiling phân tích nhiều đặc điểm của lưu lượng như tốc độ truyền dữ liệu, số lượng kết nối, giao thức sử dụng, địa chỉ IP nguồn, địa chỉ IP đích, cổng dịch vụ và thời gian tồn tại của từng luồng mạng.

6.2.2. Nguyên lý hoạt động

Hệ thống giám sát liên tục phần tiêu đề (Header) của các gói tin đi qua thiết bị mạng. Từ các thông tin thu thập được, hệ thống xây dựng hồ sơ thống kê cho từng luồng mạng (Network Flow).

Một luồng mạng được hiểu là tập hợp các gói tin có cùng địa chỉ IP nguồn, địa chỉ IP đích, giao thức truyền thông và cổng kết nối trong một khoảng thời gian nhất định.

Sau khi thu thập dữ liệu trong thời gian dài, hệ thống xác định được các thông số trung bình như:

Tốc độ truyền gói tin trung bình.

Số lượng kết nối trung bình.

Số lượng luồng mạng hoạt động.

Tỷ lệ sử dụng các giao thức TCP, UDP và ICMP.

Phân bố địa chỉ IP truy cập.

Các thông số này tạo thành hồ sơ hoạt động chuẩn của hệ thống.

6.2.3. Cơ chế phát hiện tấn công

Trong quá trình vận hành, hệ thống liên tục so sánh lưu lượng hiện tại với hồ sơ đã xây dựng.

Nếu tốc độ truyền dữ liệu hoặc số lượng kết nối tăng vượt quá ngưỡng cho phép trong thời gian ngắn, hệ thống sẽ coi đây là dấu hiệu bất thường.

Ngoài ra, đối với các cuộc tấn công DDoS, số lượng luồng mạng đến từ nhiều địa chỉ IP khác nhau thường tăng rất nhanh. Đây là đặc điểm giúp phân biệt DDoS với các cuộc tấn công DoS từ một nguồn duy nhất.

Khi cả hai dấu hiệu gồm lưu lượng tăng mạnh và số lượng luồng mạng tăng bất thường xuất hiện đồng thời, hệ thống sẽ phát sinh cảnh báo.

6.2.4. Ưu điểm

Phương pháp Activity Profiling có khả năng thích nghi với từng hệ thống vì hồ sơ hoạt động được xây dựng từ chính dữ liệu thực tế. Quá trình xử lý tương đối đơn giản, dễ triển khai trên các thiết bị mạng hiện đại và có khả năng phát hiện sớm nhiều loại tấn công DDoS.

6.2.5. Hạn chế

Độ chính xác của phương pháp phụ thuộc nhiều vào chất lượng hồ sơ ban đầu. Nếu hồ sơ không phản ánh đúng hành vi bình thường của hệ thống, khả năng phát hiện sẽ giảm. Ngoài ra, trong các trường hợp lưu lượng tăng mạnh do sự kiện hợp pháp (Flash Crowd), hệ thống có thể phát sinh cảnh báo sai nếu ngưỡng thống kê chưa được tối ưu.

6.3. Kỹ thuật phân tích tín hiệu dựa trên Wavelet (Wavelet-based Signal Analysis)

6.3.1. Khái niệm

Wavelet-based Signal Analysis là kỹ thuật phát hiện hiện đại, trong đó lưu lượng mạng được xem như một tín hiệu số biến đổi theo thời gian. Thay vì chỉ phân tích số lượng gói tin, phương pháp này nghiên cứu đặc điểm của tín hiệu trong cả miền thời gian và miền tần số nhằm phát hiện các biến động bất thường.

Kỹ thuật Wavelet đặc biệt hiệu quả trong việc phát hiện các cuộc tấn công có lưu lượng thay đổi nhanh hoặc xuất hiện theo từng chu kỳ ngắn.

6.3.2. Nguyên lý hoạt động

Lưu lượng mạng được chia thành nhiều khoảng thời gian liên tiếp (Time Window).

Đối với mỗi khoảng thời gian, thuật toán Wavelet thực hiện phép biến đổi toán học để phân tích tín hiệu thành các thành phần có tần số khác nhau.

Thông qua quá trình này, hệ thống xác định được năng lượng của từng thành phần tín hiệu và quan sát sự thay đổi theo thời gian.

Trong điều kiện bình thường, năng lượng của tín hiệu thường biến thiên ổn định. Khi xảy ra tấn công DDoS, lưu lượng tăng đột ngột sẽ làm xuất hiện các thành phần tần số bất thường với năng lượng rất lớn.

Thuật toán sẽ ghi nhận sự thay đổi này và phát sinh cảnh báo.

6.3.3. Cơ chế phát hiện

Sau khi thực hiện phép biến đổi Wavelet, hệ thống tính toán năng lượng của từng cửa sổ tín hiệu.

Nếu năng lượng vượt quá giá trị trung bình trong một khoảng thời gian xác định, thuật toán sẽ đánh dấu đây là điểm dị biệt (Anomaly).

Khi nhiều điểm dị biệt xuất hiện liên tiếp hoặc đồng thời trên nhiều thành phần tín hiệu, hệ thống xác định khả năng cao đang xảy ra một cuộc tấn công DDoS.

6.3.4. Ưu điểm

Wavelet có khả năng phân tích đồng thời theo thời gian và tần số nên phát hiện được cả các cuộc tấn công ngắn hạn và kéo dài. Độ chính xác cao hơn nhiều phương pháp thống kê truyền thống và đặc biệt hiệu quả với các cuộc tấn công có lưu lượng biến đổi liên tục.

6.3.5. Hạn chế

Thuật toán Wavelet yêu cầu năng lực tính toán tương đối lớn và việc lựa chọn tham số phân tích phù hợp cũng khá phức tạp. Vì vậy, phương pháp này thường được triển khai trên các hệ thống có cấu hình mạnh hoặc kết hợp với các nền tảng phân tích dữ liệu lớn.

6.4. Thuật toán phát hiện điểm thay đổi tuần tự (Sequential Change-Point Detection)

6.4.1. Khái niệm

Sequential Change-Point Detection là nhóm thuật toán chuyên phát hiện thời điểm mà đặc điểm thống kê của lưu lượng mạng bắt đầu thay đổi. Mục tiêu của phương pháp là xác định càng sớm càng tốt thời điểm xuất hiện cuộc tấn công để giảm thiểu thiệt hại.

Khác với Activity Profiling chỉ so sánh với hồ sơ hoạt động, phương pháp này theo dõi liên tục chuỗi dữ liệu theo thời gian nhằm phát hiện các điểm chuyển đổi bất thường.

6.4.2. Quy trình hoạt động

Quy trình xử lý thường gồm bốn bước.

Bước đầu tiên là cô lập lưu lượng (Isolate Traffic). Hệ thống sử dụng các thuật toán thống kê để tách riêng phần lưu lượng có dấu hiệu bất thường khỏi tổng lưu lượng mạng.

Bước thứ hai là lọc lưu lượng (Filter Traffic). Các gói tin được phân loại theo địa chỉ IP, giao thức, cổng dịch vụ hoặc các tiêu chí khác để xây dựng chuỗi dữ liệu theo thời gian.

Bước thứ ba là nhận diện cuộc tấn công (Identify Attack). Thuật toán CUSUM (Cumulative Sum Control Chart) hoặc các thuật toán thống kê tương tự được sử dụng để so sánh giá trị trung bình hiện tại với giá trị trung bình kỳ vọng. Khi độ lệch vượt quá ngưỡng cho phép, hệ thống xác định đã xảy ra biến động bất thường.

Bước cuối cùng là nhận diện hoạt động quét mạng (Identify Scan Activity). Ngoài việc phát hiện DDoS, thuật toán còn có khả năng nhận biết các hoạt động dò quét cổng, quét địa chỉ IP hoặc quá trình tìm kiếm mục tiêu của sâu máy tính trước khi phát động tấn công.

6.4.3. Thuật toán CUSUM

CUSUM là một trong những thuật toán thống kê được sử dụng rộng rãi trong phát hiện DDoS.

Thuật toán liên tục tính toán tổng sai lệch giữa giá trị quan sát và giá trị kỳ vọng của lưu lượng mạng.

Nếu sai lệch tích lũy vượt qua ngưỡng được cấu hình trước, hệ thống kết luận rằng đã xảy ra sự thay đổi bất thường và phát sinh cảnh báo.

Nhờ cơ chế cộng dồn sai lệch, CUSUM có khả năng phát hiện các cuộc tấn công ngay từ giai đoạn đầu khi lưu lượng mới bắt đầu tăng.

6.4.4. Ưu điểm

Sequential Change-Point Detection có khả năng phát hiện nhanh các biến động nhỏ trong lưu lượng mạng, giảm thời gian phản ứng của hệ thống và hỗ trợ phát hiện nhiều loại tấn công khác nhau như DDoS, quét cổng hay sâu máy tính.

6.4.5. Hạn chế

Việc lựa chọn ngưỡng phát hiện phù hợp khá khó khăn. Nếu ngưỡng quá thấp, hệ thống sẽ tạo nhiều cảnh báo giả; ngược lại, nếu ngưỡng quá cao, cuộc tấn công có thể không được phát hiện kịp thời. Ngoài ra, thuật toán yêu cầu dữ liệu đầu vào liên tục và ổn định để đạt hiệu quả cao.

6.5. So sánh các kỹ thuật phát hiện

Tiêu chí	Activity Profiling	Wavelet Analysis	Sequential Change-Point Detection
Nguyên lý	So sánh với hồ sơ hoạt	Phân tích tín hiệu theo	Phát hiện điểm thay đổi

Tiêu chí	Activity Profiling	Wavelet Analysis	Sequential Change-Point Detection
	động chuẩn	thời gian và tần số	thống kê
Đối tượng phân tích	Luồng mạng (Network Flow)	Chuỗi tín hiệu lưu lượng	Chuỗi thời gian của lưu lượng
Khả năng phát hiện sớm	Cao	Rất cao	Rất cao
Độ chính xác	Cao	Rất cao	Cao
Mức độ tính toán	Trung bình	Cao	Trung bình đến cao
Khả năng triển khai	Dễ	Khó hơn	Trung bình

6.6. Kết luận chương

Các kỹ thuật phát hiện DoS/DDoS đóng vai trò quan trọng trong việc bảo vệ hạ tầng mạng hiện đại. Mỗi phương pháp đều có nguyên lý hoạt động và phạm vi ứng dụng riêng. **Activity Profiling** tập trung xây dựng hồ sơ lưu lượng bình thường để nhận biết các sai lệch bất thường. **Wavelet-based Signal Analysis** khai thác các đặc điểm của tín hiệu mạng trong cả miền thời gian và miền tần số nhằm phát hiện các biến động tinh vi. Trong khi đó, **Sequential Change-Point Detection** sử dụng các mô hình thống kê để xác định thời điểm xuất hiện sự thay đổi trong lưu lượng mạng, giúp phát hiện sớm các cuộc tấn công.

Trên thực tế, các tổ chức thường kết hợp nhiều kỹ thuật phát hiện khác nhau thay vì chỉ sử dụng một phương pháp đơn lẻ. Việc tích hợp các thuật toán thống kê, phân tích tín hiệu và giám sát hành vi sẽ giúp nâng cao độ chính xác, giảm tỷ lệ cảnh báo giả và tăng khả năng ứng phó với các cuộc tấn công DoS/DDoS có quy mô lớn và ngày càng tinh vi.

CHƯƠNG VII: CHIẾN LƯỢC VÀ CÔNG CỤ ỨNG PHÓ TRONG PHÒNG VỆ (COUNTERMEASURES)

7.1. Giới thiệu

Trong những năm gần đây, các cuộc tấn công từ chối dịch vụ (DoS) và từ chối dịch vụ phân tán (DDoS) không ngừng gia tăng về quy mô, cường độ cũng như mức độ tinh vi. Với sự phát triển của các mạng Botnet và các dịch vụ tấn công thuê (DDoS-as-a-Service), nhiều cuộc tấn công có khả năng tạo ra lưu lượng lên tới hàng trăm gigabit hoặc thậm chí hàng terabit mỗi giây, vượt quá khả năng xử lý của hầu hết các hệ thống mạng truyền thống.

Do đó, việc phòng chống DoS/DDoS không thể chỉ dựa vào một thiết bị hoặc một giải pháp đơn lẻ mà cần được triển khai theo mô hình phòng thủ nhiều lớp (Defense in Depth). Mỗi lớp bảo vệ đảm nhận một vai trò khác nhau, từ phát hiện sớm, lọc lưu lượng độc hại, cân bằng tải, hấp thụ lưu lượng tấn công đến đảm bảo khả năng duy trì hoạt động của các dịch vụ quan trọng.

Theo chương trình CEH Module 09, các chiến lược ứng phó được chia thành ba nhóm chính gồm hấp thụ cuộc tấn công, hạ cấp dịch vụ và tắt hoàn toàn dịch vụ trong trường hợp khẩn cấp. Song song với đó là việc triển khai các công cụ bảo vệ chuyên dụng như tường lửa thế hệ mới, hệ thống chống DDoS chuyên dụng, IDS/IPS và các dịch vụ chống DDoS trên nền tảng đám mây.

7.2. Ba chiến lược ứng phó cốt lõi (Countermeasure Strategies)

7.2.1. Chiến lược hấp thụ cuộc tấn công (Absorbing the Attack)

Đây là chiến lược phòng thủ được ưu tiên áp dụng đối với các tổ chức có hạ tầng công nghệ thông tin lớn và yêu cầu tính sẵn sàng cao. Mục tiêu của chiến lược này là duy trì khả năng cung cấp dịch vụ ngay cả khi hệ thống đang phải chịu một lượng lớn lưu lượng tấn công.

Thay vì cố gắng chặn hoàn toàn các gói tin độc hại, hệ thống được thiết kế với nguồn tài nguyên dự phòng đủ lớn để hấp thụ lưu lượng phát sinh. Việc mở rộng băng thông Internet, tăng số lượng máy chủ, triển khai nhiều trung tâm dữ liệu và sử dụng các công nghệ phân phối lưu lượng giúp giảm tải cho từng thiết bị riêng lẻ.

Một trong những giải pháp được áp dụng phổ biến là sử dụng mạng phân phối nội dung (Content Delivery Network - CDN). CDN phân phối nội dung đến nhiều máy chủ đặt tại các khu vực địa lý khác nhau, từ đó phân tán lưu lượng truy cập và giảm áp lực lên máy chủ gốc.

Ngoài CDN, nhiều tổ chức còn triển khai công nghệ định tuyến Anycast. Với Anycast, nhiều máy chủ cùng sử dụng một địa chỉ IP công khai, cho phép lưu lượng của người dùng được tự động chuyển đến máy chủ gần nhất hoặc máy chủ còn khả năng xử lý. Khi xảy ra DDoS, lưu

lượng tấn công sẽ được phân tán trên nhiều trung tâm dữ liệu thay vì tập trung vào một địa điểm duy nhất.

Chiến lược hấp thụ cuộc tấn công có ưu điểm là duy trì được tính liên tục của dịch vụ và giảm thiểu ảnh hưởng đến người dùng hợp pháp. Tuy nhiên, giải pháp này đòi hỏi chi phí đầu tư rất lớn cho hạ tầng mạng, hệ thống máy chủ và đường truyền Internet dự phòng.

7.2.2. Chiến lược hạ cấp dịch vụ (Degrading Services)

Trong nhiều trường hợp, việc duy trì toàn bộ dịch vụ trong thời gian xảy ra DDoS là không khả thi. Khi đó, tổ chức sẽ áp dụng chiến lược hạ cấp dịch vụ nhằm ưu tiên tài nguyên cho các chức năng quan trọng nhất.

Hệ thống sẽ tự động phân loại các dịch vụ theo mức độ ưu tiên. Những dịch vụ phục vụ hoạt động cốt lõi như xác thực người dùng, xử lý giao dịch, cơ sở dữ liệu hoặc hệ thống thanh toán sẽ được ưu tiên duy trì hoạt động.

Ngược lại, các dịch vụ không thiết yếu như hình ảnh độ phân giải cao, video, báo cáo thống kê, các tiện ích phụ hoặc những chức năng ít được sử dụng sẽ được tạm thời vô hiệu hóa nhằm giảm tải cho hệ thống.

Việc cắt giảm các dịch vụ phụ giúp tiết kiệm đáng kể tài nguyên CPU, bộ nhớ, kết nối cơ sở dữ liệu và băng thông mạng. Nhờ đó, hệ thống vẫn có thể phục vụ các chức năng quan trọng mặc dù hiệu năng tổng thể bị giảm.

Chiến lược này thường được sử dụng trong các hệ thống ngân hàng, thương mại điện tử và dịch vụ công trực tuyến, nơi việc duy trì các giao dịch quan trọng luôn được ưu tiên hơn các chức năng hỗ trợ.

7.2.3. Chiến lược tắt hoàn toàn dịch vụ (Shutting Down the Services)

Đây là giải pháp cuối cùng khi tất cả các biện pháp phòng thủ khác đều không còn hiệu quả hoặc hệ thống có nguy cơ bị hư hỏng nghiêm trọng.

Trong trường hợp này, tổ chức chủ động dừng toàn bộ hoặc một phần các dịch vụ nhằm bảo vệ hạ tầng công nghệ thông tin, dữ liệu và thiết bị phần cứng.

Việc tạm thời ngừng cung cấp dịch vụ giúp tránh tình trạng quá tải kéo dài có thể dẫn đến lỗi phần cứng, mất dữ liệu hoặc gây ảnh hưởng đến các hệ thống khác trong cùng trung tâm dữ liệu.

Sau khi cuộc tấn công kết thúc, quản trị viên sẽ tiến hành kiểm tra tính toàn vẹn của dữ liệu, đánh giá tình trạng hệ thống, khôi phục cấu hình và đưa các dịch vụ hoạt động trở lại theo từng giai đoạn nhằm đảm bảo tính ổn định.

Mặc dù giải pháp này gây gián đoạn hoạt động của doanh nghiệp, nhưng trong nhiều tình huống đây là lựa chọn cần thiết để bảo vệ tài sản số và giảm thiểu thiệt hại lâu dài.

7.3. Các công cụ phòng chống DoS/DDoS chuyên dụng

Để triển khai hiệu quả các chiến lược phòng thủ nêu trên, các tổ chức thường kết hợp nhiều công nghệ bảo mật khác nhau nhằm tạo thành một hệ thống phòng vệ nhiều lớp.

7.3.1. Tường lửa thế hệ mới (Next-Generation Firewall – NGFW)

Tường lửa thế hệ mới là lớp phòng vệ đầu tiên bảo vệ hệ thống trước các cuộc tấn công từ Internet.

Không chỉ kiểm tra địa chỉ IP và cổng kết nối như tường lửa truyền thống, NGFW còn có khả năng phân tích sâu nội dung gói tin, nhận diện ứng dụng, kiểm tra người dùng và phát hiện các hành vi bất thường theo thời gian thực.

Trong phòng chống DoS/DDoS, NGFW có thể thực hiện giới hạn tốc độ kết nối (Rate Limiting), phát hiện địa chỉ IP giả mạo, chặn các gói tin không hợp lệ, giới hạn số lượng kết nối đồng thời và tự động cập nhật các chính sách bảo mật khi phát hiện dấu hiệu tấn công.

Việc triển khai NGFW giúp giảm đáng kể lượng lưu lượng độc hại trước khi chúng tiếp cận máy chủ nội bộ.

7.3.2. Thiết bị chống DDoS chuyên dụng (DDoS Mitigation Appliances)

Đây là các thiết bị được thiết kế chuyên biệt để phát hiện và xử lý các cuộc tấn công DDoS có quy mô lớn.

Các thiết bị này thường được đặt tại cửa ngõ của trung tâm dữ liệu hoặc giữa hệ thống mạng nội bộ với Internet.

Khi phát hiện lưu lượng bất thường, thiết bị sẽ phân tích đặc điểm của từng gói tin, loại bỏ lưu lượng độc hại và chỉ cho phép các gói tin hợp lệ tiếp tục đi vào hệ thống.

Quá trình này thường được gọi là Scrubbing hoặc Scrubbing Center.

Nhờ sử dụng phần cứng chuyên dụng kết hợp với các thuật toán phân tích tốc độ cao, các thiết bị chống DDoS có khả năng xử lý hàng chục đến hàng trăm gigabit dữ liệu mỗi giây.

7.3.3. Hệ thống phát hiện và ngăn chặn xâm nhập (Intrusion Detection System / Intrusion Prevention System)

IDS và IPS đóng vai trò quan trọng trong việc giám sát lưu lượng mạng và phát hiện các hành vi bất thường.

IDS có nhiệm vụ thu thập, phân tích và cảnh báo khi phát hiện dấu hiệu của các cuộc tấn công.

IPS hoạt động tương tự IDS nhưng có khả năng tự động thực hiện các biện pháp ngăn chặn như chặn địa chỉ IP, hủy phiên kết nối hoặc loại bỏ các gói tin độc hại.

Các hệ thống này sử dụng nhiều phương pháp khác nhau như phát hiện theo chữ ký (Signature-based Detection), phát hiện theo hành vi (Behavior-based Detection) hoặc phát hiện theo bất thường (Anomaly Detection).

Việc kết hợp IDS/IPS với Firewall giúp nâng cao khả năng phát hiện sớm và giảm thời gian phản ứng trước các cuộc tấn công DDoS.

7.3.4. Dịch vụ chống DDoS trên nền tảng đám mây (Cloud-based Scrubbing Services)

Đây là giải pháp được sử dụng rộng rãi bởi các doanh nghiệp lớn nhờ khả năng xử lý lưu lượng cực lớn.

Các nhà cung cấp dịch vụ đám mây sở hữu hạ tầng mạng toàn cầu với băng thông rất lớn và nhiều trung tâm dữ liệu phân bố trên nhiều quốc gia.

Khi xảy ra tấn công, lưu lượng Internet sẽ được chuyển hướng đến các trung tâm Scrubbing của nhà cung cấp. Tại đây, toàn bộ lưu lượng được kiểm tra và phân loại.

Những gói tin hợp lệ sẽ được chuyển tiếp đến máy chủ của khách hàng, trong khi lưu lượng độc hại bị loại bỏ ngay tại hệ thống đám mây.

Nhờ khả năng mở rộng linh hoạt, các dịch vụ Cloud Scrubbing có thể hấp thụ các cuộc tấn công Volumetric với quy mô hàng trăm gigabit hoặc nhiều terabit mỗi giây mà vẫn đảm bảo tính sẵn sàng của dịch vụ.

Ngoài khả năng chống DDoS, nhiều nhà cung cấp còn tích hợp Web Application Firewall (WAF), CDN, DNS Anycast và hệ thống giám sát thời gian thực nhằm nâng cao hiệu quả bảo vệ.

7.4. So sánh các công cụ phòng chống

Công cụ	Chức năng chính	Ưu điểm	Hạn chế
Next-Generation Firewall (NGFW)	Kiểm soát và lọc lưu lượng mạng	Phát hiện và ngăn chặn nhiều loại tấn công	Hiệu quả hạn chế với các cuộc tấn công bằng thông tin rất lớn
DDoS Mitigation Appliance	Phân tích và lọc lưu lượng DDoS	Xử lý tốc độ cao, phù hợp trung tâm dữ liệu	Chi phí đầu tư và vận hành cao
IDS/IPS	Phát hiện và ngăn chặn xâm nhập	Phát hiện sớm các hành vi bất thường	Có thể phát sinh cảnh báo giả nếu cấu hình chưa tối ưu
Cloud-based Scrubbing Services	Hấp thụ và lọc lưu lượng trên nền tảng đám mây	Khả năng mở rộng lớn, bảo vệ trước các cuộc tấn công quy mô lớn	Phụ thuộc vào nhà cung cấp dịch vụ và kết nối Internet

7.5. Mô hình phòng thủ nhiều lớp

Trong thực tế, không có một giải pháp đơn lẻ nào có thể ngăn chặn hoàn toàn mọi cuộc tấn công DoS/DDoS. Vì vậy, các tổ chức thường xây dựng mô hình phòng thủ nhiều lớp.

Lớp đầu tiên là Firewall và Router, có nhiệm vụ lọc các lưu lượng bất thường ngay từ biên mạng.

Lớp thứ hai là IDS/IPS, giúp giám sát, phân tích và phát hiện các dấu hiệu tấn công theo thời gian thực.

Lớp thứ ba là các thiết bị chống DDoS chuyên dụng hoặc dịch vụ Scrubbing Center nhằm loại bỏ lưu lượng độc hại trước khi chúng đến hệ thống nội bộ.

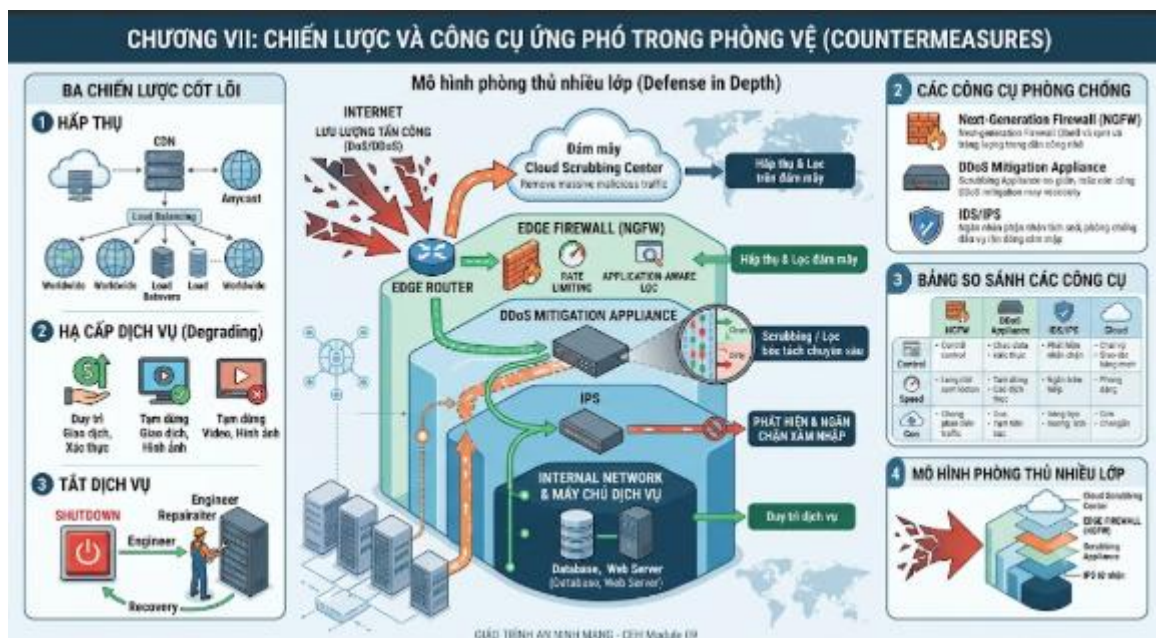
Lớp cuối cùng là các giải pháp đảm bảo tính sẵn sàng của dịch vụ như CDN, Anycast, cân bằng tải (Load Balancer) và hệ thống dự phòng tại nhiều trung tâm dữ liệu.

Việc phối hợp đồng bộ các lớp bảo vệ giúp tăng khả năng chống chịu trước nhiều loại hình tấn công khác nhau, đồng thời đảm bảo hệ thống vẫn có thể duy trì hoạt động ngay cả khi chịu áp lực từ các cuộc tấn công quy mô lớn.

7.6. Kết luận chương

Việc phòng chống các cuộc tấn công DoS/DDoS đòi hỏi sự kết hợp giữa chiến lược quản trị, quy trình ứng phó và các công nghệ bảo mật hiện đại. Ba chiến lược ứng phó gồm **hấp thụ cuộc tấn công**, **hạ cấp dịch vụ** và **tắt hoàn toàn dịch vụ** giúp tổ chức lựa chọn phương án phù hợp tùy theo quy mô và mức độ nghiêm trọng của sự cố. Bên cạnh đó, các công cụ như **Next-Generation Firewall**, **DDoS Mitigation Appliance**, **IDS/IPS** và **Cloud-based Scrubbing Services** đóng vai trò quan trọng trong việc phát hiện, lọc và giảm thiểu lưu lượng độc hại.

Trong môi trường công nghệ thông tin hiện đại, việc kết hợp nhiều lớp bảo vệ theo mô hình **Defense in Depth** cùng với công tác giám sát liên tục, cập nhật chính sách bảo mật và xây dựng kế hoạch ứng cứu sự cố sẽ giúp nâng cao khả năng chống chịu của hệ thống trước các mối đe dọa DoS/DDoS ngày càng phức tạp và có quy mô lớn.



Hình ảnh minh họa

CHƯƠNG VIII: QUY TRÌNH KIỂM THỬ XÂM NHẬP DOS/DDOS (PENETRATION TESTING)

Kiểm thử xâm nhập DoS/DDoS (Penetration Testing) là quá trình chủ động giả lập các kịch bản tấn công thực tế một cách có kiểm soát nhằm đánh giá sức chịu đựng của hạ tầng công nghệ và năng lực phản ứng của đội ngũ an ninh (SOC) (p. 2).

[Bước 1: Chấp thuận pháp lý] —> [Bước 2: Thu thập thông tin] —> [Bước 3: Chọn kịch bản & Công cụ]

|

[Bước 6: Khôi phục & Báo cáo] <— [Bước 5: Tấn công leo thang] <— [Bước 4: Thiết lập giám sát]

Bước 1: Giành quyền chấp thuận bằng văn bản (Written Permission & SLA)

- **Yêu cầu bắt buộc:** Chuyên gia kiểm thử tuyệt đối không thực hiện bất kỳ hành vi gửi gói tin thử nghiệm nào nếu không có văn bản ủy quyền pháp lý có chữ ký của cấp có thẩm quyền quản lý hệ thống.
- **Thỏa thuận mức dịch vụ (SLA):** Xác định rõ khung giờ thực hiện (thường vào giờ thấp điểm hệ thống), dải IP nguồn dùng để tấn công, và thiết lập kênh liên lạc khẩn cấp (Hotline) với đội ngũ vận hành hệ thống nếu xảy ra sự cố sập nguồn vật lý ngoài ý muốn.

Bước 2: Thu thập thông tin và xác định bề mặt tấn công (Reconnaissance)

- **Xác định mục tiêu:** Sử dụng các kỹ thuật quét mạng thụ động và chủ động để xác định kiến trúc sơ đồ mạng, dải IP công cộng (Public IP), vị trí đặt tường lửa, bộ cân bằng tải (Load Balancer) và loại hệ điều hành của máy chủ mục tiêu.
- **Định vị dịch vụ:** Tìm kiếm các cổng dịch vụ đang mở (Open ports), đặc biệt là các cổng chạy dịch vụ Web (80, 443) hoặc các dịch vụ sử dụng giao thức UDP để đánh giá nguy cơ tiềm ẩn.

Bước 3: Lập kịch bản và lựa chọn công cụ phù hợp

- **Kịch bản Tầng mạng (Network Layer):** Sử dụng các công cụ như LOIC hoặc Dereil để giả lập tấn công SYN Flood hoặc UDP Flood nhằm kiểm tra giới hạn của thiết bị định tuyến, thiết bị tường lửa (pp. 34, 36).
- **Kịch bản Tầng ứng dụng (Application Layer):** Sử dụng DoSHTTP hoặc HULK để gửi các yêu cầu liên tục tới các URL nặng (như tính năng truy vấn cơ sở dữ liệu, tìm kiếm sản phẩm) nhằm vắt kiệt CPU/RAM của máy chủ Web (pp. 35-36).

Bước 4: Thiết lập môi trường giám sát nền (Monitoring Baseline)

- Trước khi phát lệnh tấn công, hệ thống giám sát tài nguyên (như Zabbix, Grafana, PRTG hoặc hệ thống giám sát nội bộ) phải được kích hoạt để đo lường các thông số nền khi hệ thống hoạt động bình thường: Tốc độ CPU (%), dung lượng RAM tiêu thụ (GB), băng thông mạng hiện tại (Mbps), và thời gian phản hồi (Response Time) của người dùng hợp lệ.

Bước 5: Thực hiện tấn công leo thang có kiểm soát (Execution)

- Tiến hành kích hoạt công cụ và nâng dần mức độ tấn công theo từng giai đoạn (ví dụ: bắt đầu với 50 requests/s, tăng dần lên 500, 5,000, và 50,000 requests/s).
- Ghi nhận chính xác "**Ngưỡng phá vỡ**" (**Breaking Point**) — thời điểm mà hệ thống bắt đầu xuất hiện tình trạng chậm mạng, không phản hồi kết nối hoặc trả về lỗi cấu hình máy chủ quá tải (502 Bad Gateway / 504 Gateway Timeout).

Bước 6: Khôi phục hệ thống và lập báo cáo kiến nghị (Remediation & Reporting)

- **Khôi phục:** Ngừng toàn bộ các tiến trình, công cụ giả lập tấn công. Phối hợp với đội ngũ quản trị hệ thống để kiểm tra trạng thái hoạt động, đảm bảo hệ thống tự động phục hồi hoặc khởi động lại các dịch vụ một cách an toàn.
- **Lập báo cáo:** Thống kê chi tiết các điểm yếu đã phát hiện (ví dụ: kích thước hàng đợi listen queue của giao thức TCP quá nhỏ dẫn đến dễ bị SYN Flood) (p. 13). Đề xuất giải pháp cấu hình tối ưu hóa khả năng bảo mật như bật tính năng SYN Cookies, cấu hình Rate Limiting trên Web Server.

CHƯƠNG IX: PHÂN TÍCH CHUYÊN SÂU KIẾN TRÚC VÀ CƠ CHẾ KHUẾCH ĐẠI TRONG TẤN CÔNG PHẢN XẠ (DRDOS AMPLIFICATION METRICS)

Để phân tích rõ lý do tại sao tấn công Phản xạ Phân tán (DRDoS) lại có sức tàn phá khủng khiếp lên bảng thông hệ thống, báo cáo cần đi sâu vào bản chất của hệ số khuếch đại (Amplification Factor) (p. 18).

1. Bản chất kỹ thuật của việc lựa chọn giao thức UDP

- Kẻ tấn công không sử dụng giao thức TCP cho các cuộc tấn công phản xạ vì TCP bắt buộc phải qua quy trình bắt tay 3 bước. Nếu giả mạo IP nguồn, gói tin SYN-ACK phản hồi sẽ bị gửi về máy nạn nhân, nhưng do không nhận được gói tin ACK thứ 3, kết nối sẽ bị hủy và không thể kích hoạt luồng dữ liệu phản hồi lớn.
- Ngược lại, giao thức UDP (User Datagram Protocol) là giao thức không hướng kết nối. Nó không có cơ chế kiểm tra tính xác thực của địa chỉ IP nguồn. Điều này cho phép kẻ tấn công dễ dàng gửi một gói tin yêu cầu (Request) kích thước nhỏ, nhưng cấu hình trường IP nguồn trong tiêu đề gói tin thành IP của nạn nhân (p. 18). Máy chủ phản xạ (Reflector) khi nhận được sẽ tự động gửi gói tin trả lời (Response) thẳng về phía nạn nhân với dung lượng lớn hơn gấp nhiều lần (p. 18).

2. Bảng thống kê hệ số khuếch đại của các giao thức phổ biến

Hệ số khuếch đại được tính bằng công thức:

$$\text{Hệ số khuếch đại} = \frac{\text{Kích thước gói tin Response (Bytes)}}{\text{Kích thước gói tin Request (Bytes)}}$$

Các thông số định lượng thực tế của các giao thức được thể hiện trong bảng dưới đây:

Tên giao thức (Protocol)	Cổng dịch vụ (Port)	Kích thước Request trung bình	Kích thước Response tối đa	Hệ số khuếch đại trung bình
NTP (Network Time Protocol)	UDP 123	48 Bytes	24,000 Bytes	~556.9 lần
DNS (Domain Name System)	UDP 53	64 Bytes	3,500 Bytes	~28 đến 54 lần
Memcached	UDP 11211	15 Bytes	750,000 Bytes	~10,000 đến 50,000 lần
SSDP (Simple Service Discovery)	UDP 1900	300 Bytes	9,000 Bytes	~30 lần

- **Phân tích trường hợp NTP (Monlist Attack):** Kẻ tấn công gửi lệnh monlist (yêu cầu máy chủ NTP trả về danh sách 600 máy tính đã kết nối với nó gần đây nhất). Một gói tin yêu cầu chỉ vỏn vẹn 48 Bytes từ kẻ tấn công có thể kích hoạt một chuỗi các

CHƯƠNG X: QUY TRÌNH GIÁM SÁT VÀ ĐIỀU TRA SỰ CỐ DDOS DÀNH CHO ĐỘI NGŨ AN NINH (SOC DRILL)

Khi hệ thống đang chịu trận trước một trận lụt dữ liệu, đội ngũ vận hành an ninh (SOC) sẽ thực hiện quy trình điều tra phản ứng nhanh theo các bước thực tế dưới đây.

Bước 1: Trích xuất gói tin bằng công cụ lệnh TSHARK

Khi hệ thống có dấu hiệu hoạt động bất thường hoặc chậm mạng (Slow network performance), kỹ sư SOC sẽ chạy lệnh sau trên thiết bị gateway để bắt các gói tin nghi ngờ trong vòng 10 giây (p. 5):

```
bash
```

```
tshark -i eth0 -a duration:10 -w ddos_investigation.pcap
```

Hãy thận trọng khi sử dụng mã.

- -i eth0: Lắng nghe trên card mạng chính kết nối trực tiếp với Internet.
- -a duration:10: Tự động dừng tiến trình bắt gói tin sau đúng 10 giây để tránh làm đầy phân vùng ổ cứng khi lưu lượng mạng quá lớn.
- -w ddos_investigation.pcap: Xuất toàn bộ dữ liệu gói tin thô ra file định dạng .pcap để phân tích chuyên sâu.

Bước 2: Phân tích thông kê tìm địa chỉ IP nguồn tấn công

Sử dụng câu lệnh sau để lọc và tìm ra top 10 địa chỉ IP gửi nhiều gói tin nhất vào hệ thống trong thời gian diễn ra sự cố:

bash

```
tshark -r ddos_investigation.pcap -T fields -e ip.src | sort | uniq -c | sort -rn | head -n 10
```

Hãy thận trọng khi sử dụng mã.

- **Cơ chế hoạt động:** Lệnh này đọc file pcap, trích xuất duy nhất trường IP nguồn (ip.src), sau đó nhóm các địa chỉ IP trùng nhau lại và đếm số lần xuất hiện (uniq -c), cuối cùng sắp xếp giảm dần (sort -rn) để hiển thị ra các địa chỉ IP đang thực hiện flood dữ liệu rác vào máy chủ (p. 5).

Bước 3: Cấu hình quy tắc tường lửa IPTABLES để chặn khẩn cấp

Sau khi xác định được hành vi tấn công flood, kỹ sư áp dụng ngay các luật chặn cứng ở tầng nhân hệ điều hành (Kernel) (p. 5):

- *Luật 1: Giới hạn số lượng kết nối tối đa từ một IP chỉ được 20 kết nối đồng thời nhằm chống Service Request Floods (p. 11):*

bash

```
iptables -A INPUT -p tcp --syn --dport 80 -m connlimit --connlimit-above 20 -j DROP
```

Hãy thận trọng khi sử dụng mã.

- Luật 2: Chặn hoàn toàn các gói tin ICMP Echo rác để giải phóng băng thông đường truyền (Bandwidth Attacks) (p. 10):

bash

```
iptables -A INPUT -p icmp --icmp-type echo-request -j DROP
```

Hãy thận trọng khi sử dụng mã.



Hình ảnh minh họa

CHƯƠNG XI: MA TRẬN SO SÁNH GIỮA CÁC CÔNG CỤ TẤN CÔNG DOS/DDOS PHỔ BIẾN PHƯƠNG PHÁP LUẬN VÀ KẾT LUẬN BÁO CÁO

Để nội dung báo cáo rõ ràng, chi tiết, dưới đây là ma trận đối sánh kỹ thuật trực quan giữa các công cụ tấn công phổ biến được đề cập trong tài liệu CEH (p. 2):

Tiêu chí so sánh	Pandora DDoS Toolkit	High Orbit Ion Cannon (HOIC)	DoSHTTP	AnDOSid (Mobile)
Tầng mạng mục tiêu	Tầng Giao vận & Ứng dụng	Chủ yếu tầng Ứng dụng	Tầng Ứng dụng (HTTP)	Tầng Ứng dụng di động
Phương thức tấn công	HTTP min, download, combo, socket connect, max flood (p. 33)	Gửi luồng HTTP POST/GET với tệp Booster mở rộng (p. 34)	Lập lịch HTTP Flood bằng cơ chế Asynchronous Sockets (p. 35)	Giả lập HTTP POST Flood từ thiết bị cầm tay (p. 37)
Nền tảng thực thi	Quản lý qua Web Panel (Botnet) (p. 33)	Phần mềm chạy trên Windows/Linux (p. 34)	Phần mềm giao diện Windows (p. 35)	Ứng dụng chạy trên hệ điều hành Android (p. 37)

Tính năng đặc biệt	Biên thể từ Dirt Jumper, quản lý trạng thái đa luồng bot (p. 33)	Cho phép cấu hình số lượng Thread thủ công và port tự chọn (p. 34)	Tích hợp sẵn URL verification, theo dõi hiệu năng hệ thống (p. 35)	Dành riêng cho chuyên gia kiểm thử ứng dụng di động (p. 37)
---------------------------	--	--	--	---

1. Phương pháp luận phòng thủ toàn diện

Qua quá trình phân tích chi tiết, an toàn thông tin không phải là một trạng thái tĩnh mà là một quy trình vận động liên tục. Để bảo vệ tài sản số của tổ chức trước hiểm họa DoS/DDoS, không thể chỉ phụ thuộc vào một thiết bị đơn lẻ mà cần triển khai mô hình phòng thủ chiều sâu (Defense-in-Depth):

- **Ở tầng mạng lõi:** Sử dụng dịch vụ định tuyến Anycast kết hợp với hệ thống trung tâm lọc rửa lưu lượng (Scrubbing Center) của các nhà cung cấp đám mây lớn nhằm hấp thụ hoàn toàn các cuộc tấn công Volumetric lên tới hàng trăm Gbps trước khi luồng dữ liệu chạm tới cổng trung tâm dữ liệu của tổ chức (p. 9).
- **Ở tầng biên hệ thống:** Triển khai các thiết bị IPS chuyên dụng cấu hình bộ luật chữ ký để nhận diện và loại bỏ ngay lập tức cấu trúc tiêu đề gói tin dị biệt của các công cụ flood tự động.
- **At tầng ứng dụng:** Tối ưu hóa chất lượng mã nguồn hệ thống, cấu hình hệ thống bộ nhớ đệm (Caching) thông minh để giảm tải xử lý truy vấn cho cơ sở dữ liệu phía sau, triệt tiêu nguy cơ bị khai thác cạn kiệt tài nguyên bởi các câu lệnh SQL độc hại (p. 17).

2. Kết luận

Nghiên cứu toàn diện về Module 09: Denial-of-Service trong chương trình Certified Ethical Hacker (CEH) cho thấy các cuộc tấn công từ chối dịch vụ đã tiến hóa vượt bậc (p. 1). Chúng không còn là những hành vi phá hoại tự phát nhỏ lẻ mà đã trở thành những chiến dịch có tổ chức, sử dụng hạ tầng tội phạm công nghệ cao phức tạp (p. 20). Việc chủ động triển khai công tác Đánh giá kiểm thử xâm nhập (Penetration Testing) định kỳ chính là chìa khóa cốt lõi giúp tổ chức phát hiện sớm các lỗ hổng kiến trúc mạng, đo lường chính xác sức chịu đựng của hệ thống để đưa ra các phương án nâng cấp hạ tầng kịp thời, đảm bảo tính liên tục của dịch vụ và an toàn thông tin cho tổ chức (p. 2).

PHỤ LỤC A: TỪ ĐIỂN THUẬT NGỮ KỸ THUẬT CHUYÊN SÂU (GLOSSARY)

1. **DoS (Denial of Service):** Tấn công từ chối dịch vụ nhắm vào máy tính hoặc hạ tầng mạng nhằm ngăn chặn hoàn toàn khả năng truy cập tài nguyên của người dùng hợp lệ (p. 5).
2. **DDoS (Distributed Denial of Service):** Tấn công từ chối dịch vụ phân tán, sử dụng một số lượng lớn các hệ thống máy tính bị chiếm quyền điều khiển cùng đồng loạt flooding vào một mục tiêu (p. 6).
3. **Botnet:** Mạng lưới gồm các máy tính, thiết bị công nghệ (IoT) đã bị nhiễm mã độc và bị kiểm soát từ xa bởi kẻ tấn công thông qua máy chủ C&C (p. 21).
4. **Zombie:** Thuật ngữ chỉ một máy tính cá nhân hoặc máy chủ của người dùng phổ thông đã bị dính mã độc và tham gia phát tán luồng tấn công DDoS theo lệnh (p. 7).

5. **C&C Center (Command and Control Center):** Cơ sở hạ tầng máy chủ do tội phạm mạng thiết lập để gửi lệnh độc hại đến mạng lưới Botnet (p. 21).
6. **Phlashing (Permanent DoS):** Hình thức tấn công phá hoại vĩnh viễn thiết bị vật lý bằng cách gửi các bản cập nhật Firmware giả mạo chứa mã độc (bricking hệ thống) (p. 15).
7. **DRDoS (Distributed Reflection Denial of Service):** Tấn công từ chối dịch vụ phản xạ phân tán, sử dụng các máy chủ trung gian để phản xạ và khuếch đại luồng dữ liệu tấn công về phía nạn nhân (p. 18).
8. **SYN Cookies:** Cơ chế phòng vệ tầng mạng, mã hóa thông tin trạng thái vào số thứ tự (Sequence Number) của gói tin SYN-ACK để chống lại tấn công SYN Flood mà không cần cấp phát bộ nhớ trước.
9. **Three-way Handshake:** Quy trình bắt tay 3 bước tiêu chuẩn để thiết lập một kết nối tin cậy qua giao thức TCP (gồm các gói tin SYN $\rightarrow$ SYN-ACK $\rightarrow$ ACK) (p. 12).
10. **Rate Limiting:** Giải pháp an ninh giới hạn số lượng yêu cầu kết nối tối đa mà một địa chỉ IP được phép gửi đến máy chủ trong một đơn vị thời gian cố định.

PHỤ LỤC B: DANH MỤC TÀI LIỆU THAM KHẢO

1. EC-Council, *Certified Ethical Hacker (CEH) Version 9 Courseware - Module 09: Denial-of-Service*, 2014-2015 (p. 1).

2. Verisign, *DDoS Trends Report - Q4 2014*, Toàn văn nghiên cứu về xu hướng tăng trưởng kích thước tấn công lên mức trung bình 7.39 Gbps (p. 4).
3. Cisco Systems, *Defending Against Distributed Denial of Service (DDoS) Attacks*, Hướng dẫn cấu hình thiết bị định tuyến chống nghẽn băng thông hệ thống.
4. IETF (Internet Engineering Task Force), *RFC 4987: TCP SYN Flooding Attacks and Common Mitigations*, Phân tích chi tiết lỗ hổng listen queue của giao thức TCP.

BẢNG KẾ THỪA VÀ NÂNG CẤP

Bảng 1. Kế thừa và nâng cấp nội dung từ CEH Module 09

Nội dung trong CEH Module 09	Nội dung kế thừa trong đề tài	Nội dung nâng cấp, mở rộng của đề tài
Khái niệm DoS và DDoS	Trình bày đầy đủ định nghĩa, nguyên lý hoạt động và sự khác nhau giữa DoS và DDoS	Bổ sung phân tích kiến trúc tấn công hiện đại, xu hướng DDoS hiện nay và tác động đối với doanh nghiệp, tổ chức và hạ tầng Internet
Mô hình	Kế thừa mô hình Botnet gồm	Mô tả chi tiết quy trình hình thành

Nội dung trong CEH Module 09	Nội dung kế thừa trong đề tài	Nội dung nâng cấp, mở rộng của đề tài
Botnet	Botmaster, C&C Server và Zombie	Botnet, cơ chế điều khiển, vòng đời Botnet và vai trò của từng thành phần trong cuộc tấn công DDoS
Kỹ thuật phát tán mã độc	Trình bày ba phương pháp Central Source, Back-chaining và Autonomous Propagation	Phân tích sâu nguyên lý hoạt động, ưu điểm, nhược điểm, tốc độ lây lan và mức độ nguy hiểm của từng phương pháp
Phân loại các véc-tơ tấn công	Kế thừa bốn nhóm Volumetric, Fragmentation, TCP State Exhaustion và Application Layer Attack	Mở rộng bằng cách phân tích mục tiêu tấn công, tài nguyên bị ảnh hưởng, ví dụ thực tế và khả năng phát hiện của từng nhóm
Các kỹ thuật tấn công	Kế thừa SYN Flood, Peer-to-Peer Attack và Permanent DoS	Phân tích quy trình hoạt động chi tiết, nguyên nhân hình thành, ảnh hưởng tới hệ thống và bổ sung sơ đồ minh họa quá trình tấn công
Phương pháp phát hiện	Kế thừa Activity Profiling, Wavelet Analysis và Sequential Change-Point Detection	Mở rộng nguyên lý toán học, cơ chế thống kê, thuật toán CUSUM, ưu điểm, hạn chế và khả năng triển khai trong thực tế
Chiến lược phòng vệ	Kế thừa ba chiến lược Absorbing, Degrading và Shutting Down Services	Bổ sung quy trình triển khai theo nhiều lớp bảo vệ (Defense in Depth), phân tích hiệu quả của từng chiến lược trong từng tình huống

Nội dung trong CEH Module 09	Nội dung kế thừa trong đề tài	Nội dung nâng cấp, mở rộng của đề tài
Công cụ phòng chống	Kế thừa Firewall, IDS/IPS, DDoS Appliance và Cloud Scrubbing	Phân tích chức năng, kiến trúc triển khai, ưu điểm, nhược điểm và khả năng phối hợp giữa các giải pháp bảo mật
Kiến thức chuẩn CEH	Giữ nguyên nền tảng kiến thức từ Module 09	Chuẩn hóa thành báo cáo nghiên cứu khoa học bằng tiếng Việt, bổ sung diễn giải, bảng biểu, sơ đồ và nội dung phân tích học thuật

Bảng 2. Giá trị nâng cấp của đề tài so với CEH Module 09

Tiêu chí	CEH Module 09	Đề tài nghiên cứu
Mục tiêu	Giới thiệu kiến thức phục vụ đào tạo Ethical Hacker	Nghiên cứu chuyên sâu cơ chế tấn công, phát hiện và phòng vệ DoS/DDoS
Mức độ chi tiết	Kiến thức cô đọng	Giải thích đầy đủ nguyên lý hoạt động của từng kỹ thuật
Phân tích kỹ thuật	Mô tả tổng quan	Phân tích chi tiết cơ chế hoạt động, nguyên nhân, hậu quả và phương pháp phòng chống
Ví dụ minh họa	Ít ví dụ	Bổ sung nhiều ví dụ và tình huống thực tế
Sơ đồ	Sơ đồ cơ bản	Mở rộng sơ đồ kiến trúc Botnet, quy trình SYN Flood, mô hình phát hiện và mô hình phòng thủ nhiều lớp
So sánh	Chưa nhiều bảng tổng hợp	Bổ sung nhiều bảng so sánh giữa các kỹ thuật tấn công và phòng vệ

Tiêu chí	CEH Module 09	Đề tài nghiên cứu
Khả năng ứng dụng	Phục vụ học CEH	Có thể sử dụng làm tài liệu tham khảo cho sinh viên, nghiên cứu và triển khai hệ thống phòng chống DDoS
Giá trị học thuật	Giáo trình đào tạo	Báo cáo nghiên cứu tổng hợp, có phân tích, đánh giá và đề xuất giải pháp

Bảng 3. Các nội dung được bổ sung trong đề tài

Chương	Nội dung bổ sung
Chương I	Mở rộng tổng quan về DoS/DDoS, lịch sử phát triển, xu hướng tấn công hiện nay và tác động đối với an toàn thông tin
Chương II	Phân tích chuyên sâu ba phương pháp phát tán mã độc và cơ chế xây dựng Botnet
Chương III	Phân loại chi tiết bốn nhóm véc-tơ tấn công cùng nguyên lý hoạt động và ví dụ minh họa
Chương IV	Phân tích cơ chế của SYN Flood, Peer-to-Peer Attack và Permanent DoS cùng các hậu quả đối với hệ thống
Chương V	Mô tả quy trình điều khiển Botnet, kiến trúc C&C và vòng đời của một cuộc tấn công DDoS (nếu có trong đề tài)
Chương VI	Mở rộng các thuật toán phát hiện DoS/DDoS, phân tích ưu điểm, hạn chế và khả năng ứng dụng
Chương VII	Hoàn thiện các chiến lược phòng vệ, mô hình Defense in Depth và các công cụ chống DDoS hiện đại
Kết luận	Đánh giá tổng thể, tổng hợp kết quả nghiên cứu và đề xuất hướng phát triển trong tương lai

